

第3章

Internet 协议的安全性

TCP/IP 协议族在诞生之初,网络中的用户彼此之间被认为是互相信任的,没有提供任何安全措施。现今,已不能认为网络中的用户是互相信任的,不能认为网络是安全的。

3.1 Internet 协议概述

Internet 协议的主要协议及其层次关系如图 3-1 所示。

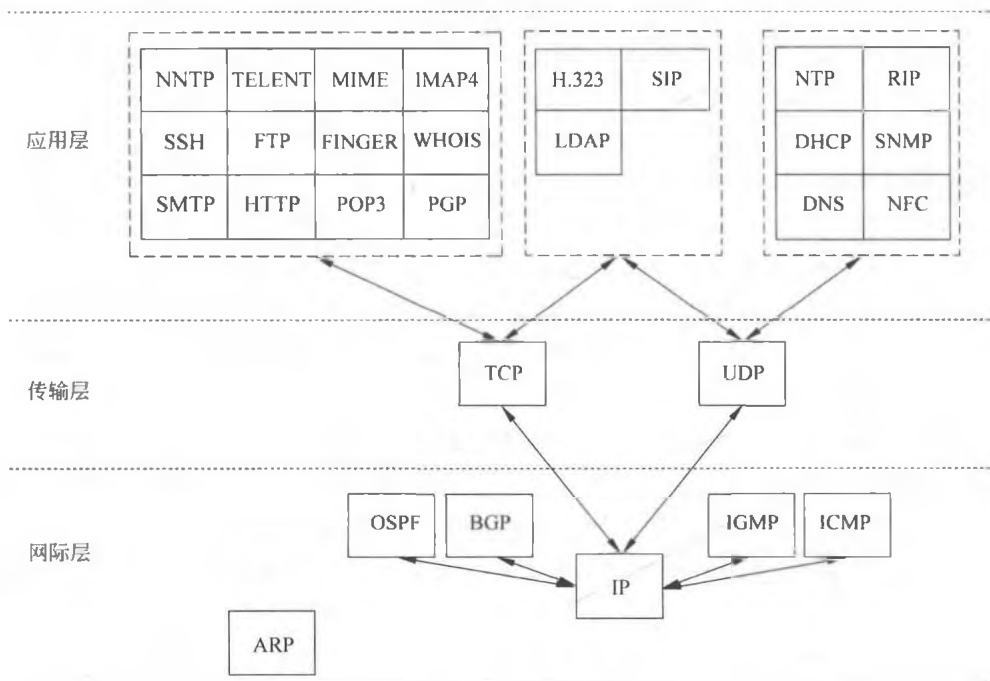


图 3-1 TCP/IP 协议族不同层次划分示意图

3.2 网际层协议

3.2.1 IP 协议

1. 概述

网际协议 (Internet Protocol, IP) 是 TCP/IP 协议族的核心,也是网际层中最重要的

协议。IP 数据报构成了 TCP/IP 协议族的基础。典型的 IP 数据报有几百个字节，其中首部占 20~60 字节，其余为数据净荷部分。

IP 层接收由更低层（例如网络接口层）发来的数据包，对数据包进行处理后交付到更高层（TCP 或 UDP 协议）；相反，IP 层也把从 TCP 或 UDP 协议来的数据包传送到更低层。IP 采用尽最大努力交付的服务，是一种不可靠的无连接数据报协议。每个 IP 数据报独立路由，各个数据报可能沿不同路径由发送方传送到接收方，因此，IP 无法确认数据报是否丢失、失序或延迟到达。另外，虽然 IP 首部中存在校验位，但此校验位只用于检测 IP 数据报首部的正确性，并没有使用任何机制保证数据净荷传输的正确性，因此，无法确认 IP 数据报是否损坏。较高层的协议（如 TCP）负责处理这些问题，以便为应用程序提供一条可靠的网络通信链路。

2. IP 协议的安全问题及防护措施

IP 协议存在一系列典型的安全问题。

（1）IP 数据报在传递过程中易被攻击者监听、窃取。此种攻击是一种被动的攻击方式，攻击者并不改变 IP 数据报的内容，但可截取 IP 数据报，解析数据净荷，从而获得数据内容。这种类型的攻击很难被检测，因为攻击过程并不影响 IP 数据报的正确传递。针对这种攻击的方法是对 IP 数据报进行加密。

（2）由于 IP 层并没有采用任何机制保证数据净荷传输的正确性，攻击者可截取 IP 数据报，修改数据报中的内容后，将修改结果发送给接收方。针对这种攻击的方法是对 IP 数据报净荷部分实行完整性检测机制。接收方在收到 IP 数据报时，可先应用完整性检测机制检测数据报的完整性，从而保证收到的 IP 数据报在传输过程中未被恶意篡改。

（3）高层的 TCP 和 UDP 服务在接收 IP 数据报时，通常假设数据报中的源地址是有效的。事实上，IP 层不能保证 IP 数据报一定是从源地址发送的。任意一台主机都可以发送具有任意源地址的 IP 数据报。攻击者可伪装成另一个网络主机，发送含有伪造源地址的数据包以欺骗接收者。此种攻击称为 IP 欺骗攻击。针对此种攻击可以通过源地址鉴别机制加以防御。一般来说，认证需要采用高层协议中的安全机制来实现。

（4）IP 数据报在传递过程中，如果数据报太大，该数据报就会被分段。也就是说，大的 IP 数据报会被分成两个或多个小数据报，每个小数据报都有自己的首部，但其数据净荷仅是大数据报净荷的一部分。每个小数据报可以经由不同的路径到达目的地。在传输过程中，每个小数据报可能会被继续分段。当这些小数据报到达接收方时，它们会被重组到一起。按照协议规则，中间节点不能对小数据报进行拼装组合。一般来说，包过滤器完成 IP 数据报的分段和重组过程。然而，正是由于 IP 数据报在传输过程中要经历被分段和重组的过程，攻击者可在包过滤器中注入大量病态的小数据报，来破坏包过滤器的正常工作。当重要的信息被分成两个 IP 数据报时，过滤器可能会错误地处理数据报，或者仅传输第 2 个 IP 数据报。更糟的是，当两个重叠的 IP 数据报含有不同的内容时，重组规则并不提示如何处理这两个 IP 数据报。许多防火墙能够重组分段的 IP 数据报，以检查其内容。

（5）使用特殊的目的地址发送 IP 数据报也会引入安全问题。如发送目的地址是直接

广播地址的 IP 数据报，发送这样的数据包是非常危险的，因为它们可以很容易地被用来攻击许多不同类型的主机。许多攻击者已将定向广播作为一种网络攻击手段。其实许多路由器具有阻止发送这类数据包的能力，因此，强烈建议网络管理员在配置路由器时，一定要启用路由器的这个功能。

3.2.2 ARP 协议

1. 概述

在通常情况下，当我们访问一台机器的时候一定可以知道它的逻辑地址，而物理地址就不一定知道。如果不知道物理地址则不能把网络层的数据包封装成 MAC 帧，完不成通信。ARP 协议正是为了解决这个问题而设置的。

在每台主机上都设置有一个所在网段上的各主机和路由器的 IP 地址到硬件地址的映射表，也称为 ARP 高速缓存。在数据发送方，当网络层的数据报要封装成 MAC 帧时，首先在高速缓存中查看有无该数据报首部的目的地址所对应的硬件地址，若有，则将该硬件地址写入 MAC 帧的目的地址中，完成数据报的封装。若无，ARP 协议则在本局域网广播发出一个 ARP 请求分组。在 ARP 请求分组中，发送方的 IP 地址和发送方硬件地址，以及目标 IP 地址都是应该写入已知的数据，要寻找的目标硬件地址写入全 0。当该请求分组到达每一个机器上时，每一台机器都要拿自己的 IP 地址和请求分组中的目标 IP 地址进行比较，如果不同则不做任何动作；若相同则发送一个 ARP 相应分组给请求方（这里不再使用广播，而是单播）。在相应分组中发送方写明了自己的硬件地址。当这一通信过程完成时，通信双方都要对自己的 ARP 高速缓存进行修改，添加上一条记录。

2. ARP 协议的安全问题及防护措施

通过上述 ARP 协议的工作原理可知，一名黑客只要能把他的主机成功插入某个网段，这台主机就能够接收到所在网段的 ARP 请求分组，从而获知该网段上主机 IP 和 MAC 地址的对应关系。从这里也可以看出，ARP 攻击仅仅在内网进行，它无法对外网（互联网、非本区域内的局域网）进行攻击。局域网中有一台主机 C，其 MAC 地址为 00-aa-00-F2-c8-04，现在假设它感染了 ARP 木马。那么主机 C 将会向某主机 A 发送一个伪造的 ARP 响应，告知主机 A：主机 B 的 IP 地址 192.168.10.8 对应的 MAC 地址是 00-aa-00-F2-c8-04（其实是主机 C 的 MAC 地址），于是，主机 A 将这个对应关系写入自己的 ARP 缓存表中。以后当主机 A 向主机 B 发送数据时，都会将本应发往主机 B 的数据发送给攻击者（主机 C）。同样地，如果攻击者向主机 B 也发送一个伪造的 ARP 响应，告诉主机 B：主机 A 的 IP 地址 192.168.0.1 对应的 MAC 地址是 00-aa-00-F2-c8-04，主机 B 也会将数据发送给攻击者。至此攻击者就控制了主机 A 和主机 B 之间的流量，他可以选择被动地监测流量，获取密码和其他涉密信息，也可以伪造数据，改变主机 A 和主机 B 之间的通信内容。这种攻击称为 ARP 欺骗。

为了解决 ARP 攻击问题，可以在网络中的交换机上配置 802.1x 协议。IEEE 802.1x 是基于端口的访问控制协议，它对连接到交换机的用户进行认证和授权。在交换机上配置 802.1x 协议后，攻击者在连接交换机时需要进行身份认证（结合 MAC、端口、账户、

VLAN 和密码等), 只有通过认证后才能向网络发送数据。攻击者未通过认证就不能向网络发送伪造的 ARP 报文。

另外, 建立静态 ARP 表, 也是一种有效地抵抗 ARP 攻击的方法, 而且对系统影响不大。缺点是破坏了动态 ARP 协议。

3.2.3 ICMP 协议

1. 概述

Internet 控制报文协议 (Internet Control Message Protocol, ICMP) 是一个重要的错误处理和信息处理协议, 运行在网际层。它可以用来通知主机到达目的地的最佳路由, 报告路由故障, 或者因网络故障中断某个连接。ICMP 的主要功能之一是向 IP 节点发送一个简单消息, 并将消息回显到发送主机。因而, 它可以提供目的节点的可达性和到达目的节点所采用的传输路径等信息, 在网络监控和故障诊断方面具有重要作用, 是网络管理员常用的两个监控工具——Ping 和 Traceroute 的重要组成部分。

ICMP 提供了 IP 路由和交付问题的关键反馈信息, 以及重要的 IP 诊断和控制能力, 可用于网络的可达性分析、拥塞控制、路由优化和超时错误报告等方面[Jeffrey 等 2014]。ICMP 最典型的用途是差错报告。例如, 当某个网关发现传输错误时, 该协议会立即向信源主机发送 ICMP 报文, 报告出错信息, 让信源主机采取相应处理措施。在运行 Telnet、FTP 或 HTTP 会话时, 通常会遇到如“目的网络不可达”之类的错误报文, 这些报文就是在 ICMP 中产生的。

IPv6 有新版本的 ICMP。ICMPv6 与 ICMPv4 的很多消息是相似的, 如 Echo 请求与应答消息、路由请求和公告等, 但 ICMPv6 也新增了一些消息, 如路由器重编号等。

2. ICMP 协议的安全问题及防护措施

ICMP 能够提供有关网络配置和连接状态等信息, 为网络监控和故障诊断提供了重要依据。然而, 黑客也能够利用 ICMP 提供的这些信息, 进行各种网络攻击和信息侦察。例如, 一些黑客会滥用 ICMP 来中断某些连接, 网上流行的 nuke.c 黑客程序就采用了这类攻击方式。此外, ICMP 还存在一些典型的安全问题。

(1) ICMP 重定向攻击。ICMP 可以用来对主机之间的消息进行重定向, 同样, 黑客也能够用 ICMP 对消息进行重定向, 进而使得目标机器遭受连接劫持和拒绝服务等攻击。一般来说, 重定向消息应该仅由主机执行, 而不是由路由器来执行。仅当消息直接来自路由器时, 才由路由器执行重定向。然而, 网络管理员有时可能会使用 ICMP 创建通往目的地的新路由。这种非常不谨慎的行为最终会导致非常严重的网络安全问题。

(2) ICMP 路由器发现攻击[James 等 2014]。在进行路由发现时, ICMP 并不对应答方进行认证, 这使得它可能遭受严重的中间人攻击。例如, 在正常的路由器响应 ICMP 询问之前, 攻击者可能会假冒正常的路由器, 使用伪造的响应信息应答 ICMP 询问。由于在路由发现的过程中, ICMP 并不对应答方进行认证, 因此接收方将无法知道这个响应是伪造的。

(3) 防火墙穿越攻击。通过防火墙穿越攻击技术 (Firewalking), 攻击者能够穿越某

个防火墙的访问控制列表和规则集，进而确定该防火墙过滤的内容和具体的过滤方式。尽管防火墙面临着启用 ICMP 所带来的风险，但在防火墙上封堵所有的 ICMP 消息并不妥当。这是因为主机常采用一种称为 Path MTU 的机制，来测试究竟多大的数据包可以不用分段发送，而这种测试需要依赖于地址不可达的 ICMP 数据包穿过防火墙。

3.2.4 IGMP 协议

1. 概述

IGMP (Internet Group Management Protocol) 作为因特网组播管理协议，是 TCP/IP 协议族中的重要协议之一，所有 IP 组播系统（包括主机和路由器）都需要支持 IGMP。IGMP 运行于主机和组播路由器之间，用来在 IP 主机和与其直接相邻的组播路由器之间建立、维护组播组成员关系。到目前为止，IGMP 共有三个版本，即 IGMP v1、v2 和 v3。

IGMP 实现的主要功能包括：主机通过 IGMP 通知路由器希望接收或离开某个特定组播组的信息；路由器通过 IGMP 周期性地查询局域网内的组播组成员是否处于活动状态，实现所连网段组成员关系的收集与维护。

2. IGMP 协议的安全问题及防护措施

IGMP 组播报文在 IP 数据包的基础上封装了组播地址等信息，鉴于组播报文基于 UDP 进行传输并缺少用户认证措施，网络中任何主机都可以向组播路由器发送 IGMP 包，请求加入或离开，导致非法用户很容易加入组播组，窃听组播数据或者发动其他针对计算机网络系统的攻击。目前，针对 IGMP 协议的攻击主要有以下几种：

(1) 利用查询报文攻击。利用具有较低数值的 IP 地址路由器发送伪造的查询报文，由当前的查询方转变为响应查询请求，并且不再发出查询报文。攻击产生的效果包括：组播路由器对子网内各主机的加入请求不做任何响应，将屏蔽合法用户；组播路由器对子网内主机撤离报文不做响应，造成该子网内不存在组播用户，但是，组播数据又不断向该子网组播路由器发送请求报文，浪费有限的带宽和资源。

(2) 利用离开报文进行 DOS 攻击。子网内非法用户通过截获某个合法用户信息来发送伪造的 IGMP 离开报文，组播路由器接收到报文后误认为该合法用户已经撤离该组播组，则不再向该用户发送询问请求，导致该合法用户不能再接收到组播数据包，造成拒绝服务攻击。

(3) 利用报告报文攻击。非法用户伪装报告报文，或截获合法用户的报告报文向组播路由器发送伪造报文，使组播路由器误以为有新用户加入，于是将组播树扩展到非法用户所在的子网，此后非法用户就可以接收到来自组播路由的组播报文，并分析该报文以展开新的攻击。

IGMP 安全性的基本要求是只有注册的合法主机才能够向组播组发送数据和接收组播数据。但是，IP 组播很难保证这一点。首先，IP 组播使用 UDP，网络中任何主机都可以向某个组播地址发送 UDP 包；其次，Internet 缺少对于网络层的访问控制，组成员可以随时加入和退出组播组；最后，采用明文传输的 IGMP 组播报文很容易被窃听、冒充和篡改，使得组播安全性问题仍然是一个技术难点。

针对以上安全问题，一种有效的安全增强措施是利用 IGMP v3 的扩展性在组播报文中未使用的辅助字段部分增加认证信息，即在每个首次加入组播的报文中添加关联主机身份的认证信息，组播路由器接收到认证信息并通过公钥密码技术实现成员身份的认证，随后，在发送给组播成员的查询信息中添加成功/失败标识的认证信息。通过此认证机制来保证 IGMP 的安全运行。

3.2.5 OSPF 协议

1. 概述

由于 Internet 规模太大，所以常把它划分成许多较小的自治系统（Autonomous System, AS）。自治系统内部的路由协议称为内部网关协议，自治系统之间的协议称为外部网关协议。常见的内部网关协议有 RIP 协议和 OSPF 协议；外部网关协议有 BGP 协议。OSPF 协议和 BGP 协议都位于网络层，但 RIP 协议位于应用层。OSPF 协议是分布式的链路状态路由协议。链路在这里代表该路由器和哪些路由器是相邻的，即通过一个网络是可以连通的。链路状态说明了该通路的连通状态以及距离、时延、带宽等参数。在该协议中，只有当链路状态发生变化时，路由器才用洪泛法向所有路由器发送路由信息。所发送的信息是与本路由器相邻的所有路由器的链路状态。为了保存这些链路状态信息，每个路由器都建立有一个链路状态数据库，因为路由器交换信息时使用的是洪泛法，所以每个路由器都存有全网的链路状态信息，也就是说每个路由器都知道整个网络的连通情况和拓扑结构。这样每个路由器都可以根据链路状态数据库的信息来构造自己的路由表。路由表内包含有数据包去往目的地地址的下一跳路由信息。OSPF 协议是 TCP/IP 工作的基础。

2. OSPF 协议的安全问题及防护措施

OSPF 的报文中包含了认证类型以及认证数据字段，如图 3-2 所示。其中主要有密码认证、空认证以及明文认证这 3 种认证模式。明文认证是将口令通过明文的方式来进行传输，只要可以访问到网络的人都可以获得这个口令，易遭受来自网络内部的攻击。密码认证则能够提供良好的安全性。为接入同一个网络或者是子网的路由器配置一个共享密钥，然后这些路由器所发送的每一个 OSPF 报文都会携带一个建立在这个共享密钥基础之上的消息认证码。当路由器接收到报文之后，根据路由器上的共享密钥以及接收到的报文通过 MD5 Hash 函数生成一个消息认证码，并将生成的消息认证码与接收到的消

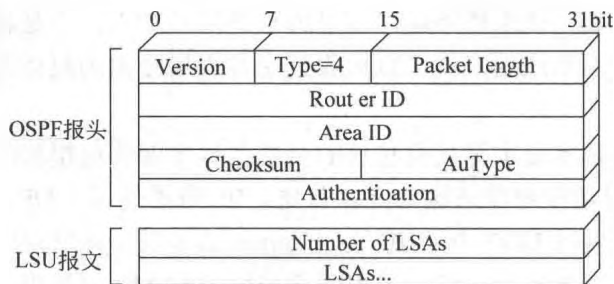


图 3-2 OSPF 报文结构

息认证码进行对比,如果两者一致就接收,反之则丢弃。OSPF 协议规定了认证域,但其作用非常有限。主要原因有:

(1) 即使 OSPF 提供了较强的认证,但某些节点仍然使用简单的口令认证。那些能够戏弄路由协议的人也就有能力收集到本地以太网上传送的口令。

(2) 在路由对话中,如果有一个合法的用户遭到破坏,那么它的消息就不再可信。

(3) 在许多路由协议中,每台机器只对它邻近的计算机对话,而这些邻近的计算机将会重复旧的会话内容。这样,欺骗就会得到传播扩散。路由信息确定了两条通道:一条是从主叫机器到目标主机,另一条是从目标主机返回到主叫机器。第2条通道可以是第1条的逆通道,也可以不是。当它们不是逆通道的时候,就叫非对称路由。这种情况在 Internet 上非常普遍。当网络有多个防火墙时,就会产生问题。从安全的角度看,返回通道通常更加重要。当目标主机遭到攻击的时候,反向流动的数据包是通过什么通道到达攻击主机的呢?如果敌人能够破坏路由机制,那么目标主机就会被欺骗,使其相信敌人的机器是一台真正可信赖的机器。如果这种情况发生,那么依赖于源地址验证的认证机制将会失败。

3.2.6 BGP 协议

1. 概述

BGP (Border Gateway Protocol) 是边界网关协议,它将单一管理的网络转化为由多个自治系统分散互联的网络。它通常工作于 ISP 内部或 ISP 之间,有时也工作于 Intranet 内部。BGP 使用 TCP 作为路由交换的底层传输协议,其以增量的更新实现路由信息交换。首个 BGP 协议版本在 RFC1105 中规定,目前实际运行版本为 BGP-4 (RFC1771)。有关 BGP 的详细描述可参阅相关文献[Stewart 1999]。

2. BGP 协议的安全问题及防护措施

BGP 协议最主要的安全问题在于:每个自治系统向外通告自己所拥有的 CIDR (Classless Inter-Domain Routing) 地址块,并且协议无条件信任对等系统的路由宣告,这就导致一个自治系统向外通告不属于自己的前缀时,也会被 BGP 用户认为合法,从而接受和传播。有研究人员[Li 等 2013]将问题归结为 BGP 缺乏一个安全可信的路由认证机制,即 BGP 无法对所传播的路由信息的安全性进行验证。为了抵抗针对 BGP 协议的攻击,研究人员主要提出了两类方案:路由认证类方案和前缀劫持检测类方案。

路由认证类方案利用数字证书、签名和其他密码学技术来保护路由信息的真实性和完整性。

(1) 首先出现的是针对劫持 BGP TCP 会话的 MD5 BGP 认证技术[Heffernan 1998]。会话者通过验证 TCP 伪首部、首部、数据段和共享秘密的 MD5 杂凑值,来实现认证。这种方法比较成熟,也具有非常高的效率,但是其安全性随着 MD5 算法的安全性减弱已经逐渐降低。

(2) S-BGP 方案[Kent 等 2000a, 2000b]利用 PKI 技术来增强 BGP 的安全性。该方案在 BGP 会话者接收到的整个路径上提供数字签名链。这种方案受到 PKI 技术的制约,

存在计算开销大等问题。同时，受制于各厂商和管理机构的标准难于统一，该方案推广与部署困难。

(3) 为了解决 S-BGP 方案不易部署等缺陷，出现了许多基于 S-BGP 的改进方案。如 Cisco 公司的 soBGP 方案[White 2003]、IRV (Interdomain Routing Validation) 方案[Goodell 等 2003]以及 IETF 的 SIDR 工作组开发的 RPKI (Resource Public Key infrastructure) & BGPsec 方案[Lepinski 2012a, 2012b]。

前缀劫持检测类方案利用异常检测 (Anomaly Detection) 技术提取 BGP 协议运行中的异常信息，对前缀劫持行为进行检测，从而提高 BGP 的安全性。

(1) 多源 AS (Multiple Origin AS, MOAS) 检测技术[Zhao 等 2001]通过获取网络中控制平面的信息，对比 MOAS 列表的一致性，来区分有效的 MOAS 和攻击的 MOAS。PHAS (Prefix Hijack Alert System) 检测技术通过审查 BGP 协议获得的路由数据，发现前缀劫持威胁，并向管理者通报路由异常[Lad 等 2006]。

(2) 主动探测技术是利用数据平面反馈的信息来发现前缀劫持行为。根据观测点 (Vantage Point) 与被测自治系统位置的对应关系，可以分为由外及内探测[Zheng 等 2007]和由内及外探测[Zhang 等 2010]两类主动探测技术。

为了综合利用以上两类检测技术的优点，研究人员也提出了将主动探测技术和 MOAS 检测技术结合的前缀劫持混合检测技术[Hu 等 2007]。

3.3 传输层协议

本节主要讨论传输层协议及其安全性分析。传输层的任务是在源主机和目的主机之间提供可靠的、性价比合理的数据传输功能，向下利用网络层提供给它的服务，向上为其用户（通常为应用层中的进程）提供高效、可靠和性价比合理的服务。传输层的存在使得传输服务有可能比网络服务更加可靠，丢失的分组和损坏的数据可以在传输层上检测出来，并进行纠正。Internet 传输层有两个主要协议，一个是面向连接的 TCP 协议，一个是无连接的 UDP 协议。

3.3.1 TCP 协议

1. 概述

TCP 是一个面向连接的可靠传输协议，提供了一些用户所期望的而 IP 协议又不能提供的功能。如 IP 层的数据包非常容易丢失、被复制或错误的次序传递，无法保证数据包一定被正确递交到目标端。而 TCP 协议会对数据包进行排序和校验，未按照顺序收到的数据包会被重排，而损坏的数据包也可以被重传。TCP 协议的原始正式定义位于 RFC793 中，此外在 RFC1122 中详细阐述了一些错误的修补方案，在 RFC1323 中又进一步作了扩展。

2. TCP 协议的安全问题及防护措施

目前针对 TCP 协议的攻击主要可以划分为以下三类。

第一类攻击是针对 TCP 连接建立阶段的三次握手过程。TCP 是一个面向连接的协议，即在数据传输之前要首先建立连接，然后传输数据，当数据传输完毕后释放所建立的连接。TCP 使用三次握手来建立连接，这种方式大大增强了传输的可靠性，如防止已失效的连接请求报文段到达被请求方，产生错误造成资源的浪费。具体过程如图 3-3 所示。但与此同时，三次握手机制却给攻击者提供了可以利用的漏洞，这类攻击中最常见的就是 SYN FLOOD 攻击，攻击者不断向服务器的监听端口发送建立 TCP 连接的请求 SYN 数据包，但收到服务器的 SYN 包后却不回复 ACK 确认信息，每次操作都会使服务器端保留一个半开放的连接，当这些半开放连接填满服务器的连接队列时，服务器便不再接受后续的任何连接请求，这种攻击属于拒绝服务（DoS）攻击。防御这类攻击的主要思路是在服务器前端部署相应的网络安全设备（如防火墙设备）对 SYN FLOOD 攻击数据包进行过滤。

第二类攻击针对 TCP 协议不对数据包进行加密和认证的漏洞，进行 TCP 会话劫持攻击。TCP 协议有一个关键特征，即 TCP 连接上的每一个字节都有它自己独有的 32 位序列号，数据包的次序就靠每个数据包中的序列号来维持。在数据传输过程中所发送的每一个字节，包括 TCP 连接的打开和关闭请求，都会获得唯一的标号。TCP 协议确认数据包的真实性的主要根据就是判断序列号是否正确，但这种机制的安全性并不够，如果攻击者能够预测目标主机选择的起始序号，就可以欺骗该目标主机，使其相信自己正在与一台可信主机进行会话。攻击者还可以伪造发送序列号在有效接收窗口内的报文，也可以截获报文并篡改内容后再发送给接收方。防御此类攻击的思路是在 TCP 连接建立时采用一个随机数作为初始序列号，规避攻击者对序列号的猜测。

第三类攻击是针对 TCP 的拥塞控制机制的特性，在 TCP 连接建立后的数据传输阶段进行攻击，降低网络的数据传输能力。拥塞控制是 TCP 的一项重要功能，所谓拥塞控

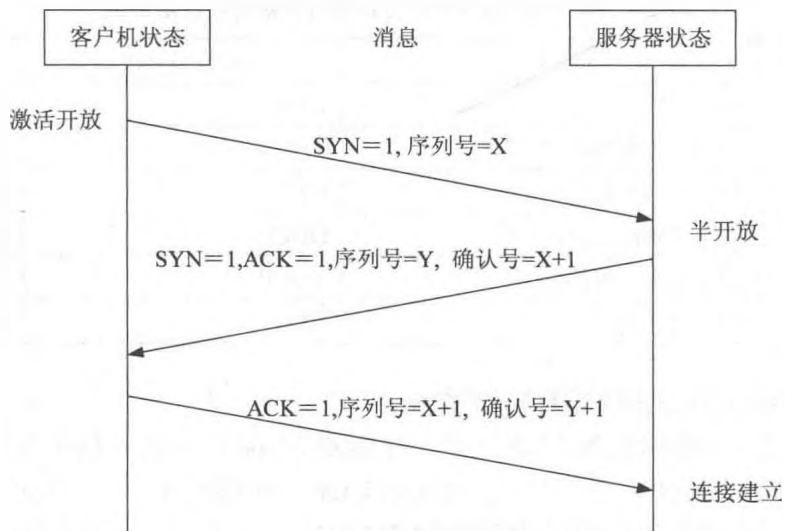


图 3-3 TCP 三次握手连接建立过程

制就是防止过多的数据注入网络，使网络中的链路和交换结点（路由器）的负荷不致过载而发生拥塞，TCP 的拥塞控制主要有以下 4 种方法：慢启动、拥塞避免、快重传和快恢复。发送端主机在确定发送报文段的速率时，既要考虑接收端的接收能力，又要考虑网络的传输能力。因此，每一个 TCP 连接都需要维护接收窗口和拥塞窗口两个状态变量，接收窗口是接收端主机根据其目前的接收缓存大小所许诺的最新窗口值；拥塞窗口的大小表示了当前网络的传输能力，由发送端设置。发送窗口取这两者中的较小值。攻击者会利用发送端计算拥塞窗口的漏洞，通过降低拥塞窗口大小来降低发送窗口的大小。拥塞窗口的计算采用了所谓的慢启动（slow start）算法，其具体特征就是拥塞窗口在传输正常时成指数增长，增长到一定阈值后按线性增长，一旦出现数据包传输超时，则拥塞窗口变为最小值，阈值变为原来一半。有经验的攻击者可以利用这种特性，周期性地制造网络关键节点的拥塞，不断触发拥塞窗口的慢启动过程，最终达到降低正常数据传输能力的目的。因为此类攻击的具体手段比较灵活，防御此类攻击的难度较大，需要网络管理人员实时监测网络的异常流量，避免攻击者制造网络关键节点的拥塞。

3.3.2 UDP 协议

1. 概述

相较于 TCP 提供的丰富功能，UDP 协议只在 IP 的数据报服务之上增加了很少的一点功能，即端口的功能和差错检测的功能。虽然 UDP 用户数据报只能提供不可靠的交付，但 UDP 在某些方面有其特殊的优点：第一，发送数据之前不需要建立连接，因此减少了开销和发送数据之前的时延；第二，不使用拥塞控制，也不保证可靠交付，因此，主机不需要维持许多参数的、复杂的连接状态表；第三，UDP 用户数据报只有 8 个字节的首部开销；第四，由于没有拥塞控制，网络出现的拥塞不会使源主机的发送速率降低。这对某些实时应用是很重要的。

表 3-1 列出了常用的几种使用 UDP 协议进行传输的应用层协议及相应端口号。

表 3-1 常用的使用 UDP 协议进行传输的应用层协议

序 号	应用名称	应用层协议	端口号
1	域名系统	DNS	53
2	简单文件传输协议	TFTP	69
3	网络时间协议	NTP	123
4	动态主机配置协议	DHCP	67、68
5	简单网络管理协议	SNMP	161
6	网络文件系统	NFS	2049

2. UDP 协议的安全问题及防护措施

DoS 攻击是一种最常见的 UDP 攻击，而 UDP Flood 攻击又是 DoS 攻击中最普遍的流量型攻击。其攻击原理：攻击源发送大量的 UDP 小包到攻击目标，目标可以是服务器或者网络设备（前提是攻击目标已经开放 UDP 端口），使其忙于处理和回应 UDP 报文，

系统资源使用率飙升，最后导致该设备不能提供正常服务或者直接死机，严重的会造成全网瘫痪。可以说 UDP 攻击是一种消耗攻击目标资源，同时也消耗自己资源的攻击方式，技术含量较低。

使用 UDP 进行传输的应用层协议之间差异极大，因此不同情况下的 UDP 攻击需要采取不同的防护手段：（1）如果攻击包是大包，则根据攻击包大小设定包碎片重组大小，通常不小于 1500，极端情况下可以考虑丢弃所有 UDP 碎片；（2）当攻击端口为业务端口，根据该业务 UDP 最大包长设置 UDP 最大包以过滤异常流量；（3）当攻击端口为非业务端口，通常通过设置 UDP 连接规则，要求所有去往该端口的 UDP 包，必须首先与 TCP 端口建立 TCP 连接，不过这种方法需要借助专业安全设备。

3.4 应用层协议

3.4.1 RIP 协议

1. 概述

RIP (Routing Information Protocol) 是一种动态内部路由/网关协议，适用于简单的 IP 网络。该协议虽然解决的是网络互联的路由问题，但它是应用层协议。RIP 协议最早在 RFC 1058 中提出，RIPv2 (RFC1723) 是它的改进方案。RIPv2 新增了变长子网掩码的功能，支持无类域间路由、支持组播、支持认证功能，同时对 RIP 路由器具有后向兼容性。

RIP 采用距离矢量算法与相邻的路由器交换路由信息，它以“跳数”（即 metric）来衡量到达目的地的距离。路由器到直连网络的 metric 标记为 0，每经过一个路由器到达下一网络时 metric 增加 1。为限制收敛时间，RIP 规定一条有效路由信息的 metric 不能超过 15，这就使得该协议不能应用于大型的网络。

RIP 的工作原理如下：（1）路由器最初启动时只包含了其直连网络的路由信息，随后定期（30s）和相邻路由器交换路由信息（就是路由器当前的路由表），路由信息以 RIP 报文传送。（2）路由器根据接收到的 RIP 报文来更新路由表，具体方法是添加或更新自己的路由表项。（3）如果接收到与已有表项的目的地址相同的路由信息，则分为三种情况对待：第一种情况，已有表项的来源端口与新表项的来源端口相同，那么根据最新的路由信息更新其路由表；第二种情况，已有表项与新表项来源于不同的端口，那么比较它们的 metric 值，将 metric 值较小的一个作为自己的路由表项；第三种情况，新旧表项的 metric 值相等，通常的处理方法是保留旧的表项。（4）若接收到的目的网络不在自己的路由表中，则把该项目加到路由表中，并将其 metric 值加 1。经过一系列路由更新，网络中的每个路由器都具有一张完整的路由表，这个过程称为收敛。RIP 协议使用 UDP 的 520 端口来发送和接收 RIP 报文。路由器每隔 30s 向其邻居路由器发送本地路由表。如果经过 180s 都没有接收到更新报文，那么将其标记为不可达，即 metric 值标记为 16。如果在其后的 120s 仍然没有收到更新信息，就将该路由从路由表中删除。

2. RIP 协议的安全问题及防护措施

RIPv1 有其固有的不安全因素，它没有使用认证机制并使用不可靠的 UDP 协议进行传输。RIPv2 的分组格式中包含了一个选项可以设置 16 个字符的明文加密字符串或者对 MD5 杂凑值的签名。虽然 RIP 报文很容易伪造，但 RIPv2 中对 MD5 杂凑值的签名与认证使得欺骗的操作难度大大提高。攻击者可以伪造 RIP 路由更新信息，并向邻居路由器发送，伪造内容为目的网络地址、子网掩码地址与下一条地址，经过若干轮的路由更新，网络通信将面临瘫痪的风险。此外，攻击者会利用一些网络嗅探工具（如 tcpdump 和 rprobe 等），来获得远程网络的 RIP 路由表，通过欺骗工具（如 srip）伪造 RIPv1 或 RIPv2 报文，再利用重定向工具（如 fragroute）截取、修改和重写向外发送的报文，以控制网络中的报文信息。

针对 RIP 的不安全因素，中小型网络通常采取以下的两种防范措施：

（1）将路由器的某些接口配置为被动接口，配置为被动接口后，该接口停止向它所在的网络广播路由更新报文，但是允许它接收来自其他路由器的更新报文。

（2）配置路由器的访问控制列表，只允许某些源 IP 地址的路由更新报文进入列表。

目前，大多数企业网络使用的是采用 MD5 安全机制的 RIPv2 协议，或者是移植了安全认证机制的 OSPF 协议来提高安全性。

3.4.2 HTTP 协议

1. 概述

超文本传输协议（Hyper Text Transfer Protocol, HTTP）是一种承载于 TCP 协议之上的应用层协议，能够从服务器传输超文本到本地浏览器，是互联网上应用最广泛的一种网络协议。HTTP 协议是一个客户端终端和服务端之间请求和应答的标准，具体过程：首先由客户端发起一个请求，建立到服务器指定端口（默认是 80 端口）的连接，HTTP 服务器接收请求后，会向客户端返回一个状态，包括协议版本号、成功或错误的代码和返回内容等信息，客户端收到信息后通过浏览器显示内容，最后断开连接。

2. HTTP 协议的安全问题及防护措施

由于 HTTP 协议设计之初未进行安全方面的考虑，数据是直接通过明文进行传输的，不提供任何方式的数据加密，因此存在较大的安全缺陷。

（1）攻击者可以通过网络嗅探工具轻易获得明文的传输数据，从而分析出特定的敏感信息，如用户的登录口令、手机号码和信用卡号码等重要资料。

（2）HTTP 协议是一种无状态的连接，在传输客户端请求和服务端响应时，唯一的完整性检验就是在报文头部包含了数据传输长度，而未对传输内容进行消息完整性检测，攻击者可以轻易篡改传输数据，发动中间人攻击，因此 HTTP 协议不适合传输重要信息。

针对 HTTP 协议的这些安全问题，超文本传输安全协议（Hyper Text Transfer Protocol Secure, HTTPS）在 HTTP 协议和 TCP 协议之间增加了安全层来增强安全性，安全层主要通过安全套接层（Secure Sockets Layer, SSL）及其替代协议传输层安全协议（Transport Layer Security, TLS）实现。与 HTTP 协议不同，SSL 协议通过 443 端口进行传输，主

要包含记录协议 (SSL Record Protocol) 和握手协议 (SSL Handshake Protocol), 记录协议确定了对传输层数据进行封装, 具体实施加密解密、计算和校验等安全操作。握手协议使用 X.509 认证, 用于验证传送数据, 协商加密算法, 并利用非对称加密算法进行身份认证和生成会话密钥等操作, 从而对通信双方交换的数据加密, 保证客户与服务器应用之间的通信不被攻击者窃听。

HTTPS 协议通过增加安全层, 可实现双向身份认证、生成会话密钥、传输数据加密、数据完整性验证和防止数据包重放攻击等安全功能, 主要改进在于使用非对称加密算法在不可信的互联网上安全传输了用来对称加密的会话密钥, 从而建立了安全信道, 因此很多银行和邮箱等安全级别较高的服务都使用 HTTPS 协议。但由于 HTTPS 协议会额外增加握手过程并对数据进行加密, 因此会在一定程度上拖慢网页加载速度。

由于 SSL 使用了非对称加密算法来传输会话密钥, 在大多数情况下, HTTPS 协议本身不会直接遭遇威胁, 针对 HTTPS 协议的攻击方式主要是发生在 SSL 连接还未发生时的中间人攻击, 利用 SSLstrip 工具可攻击从非安全连接到安全连接的通信, 即从 HTTP 到 HTTPS 的过程中发起中间人攻击, 模拟客户端向服务器提供证书, 再从安全网站收到流量提供给客户端, 进而窃取敏感信息。

多数 SSL 加密的网站都使用名为 OpenSSL 的开源软件包, 2014 年 4 月曾爆发著名的心脏滴血 (Heartbleed) 漏洞, 影响了全球绝大多数使用 HTTPS 协议的安全网站, 目前该漏洞已被修补。

3.4.3 TELNET 协议

1. 概述

远程登录 (Telnet) 协议是 TCP/IP 协议族中的一员, 是 Internet 远程登录服务的标准协议。Telnet 协议可以让用户使用的本地计算机成为远程主机系统的一个终端。用户可以在本地终端上使用 Telnet 协议远程访问服务器并输入命令, 命令会在服务器上执行, 并将执行结果返回给用户。Telnet 协议侧重于访问远程主机所拥有的信息资源, 如果希望在本机计算机与远程主机间传递文件, 那么相较而言 FTP 协议会更加快捷有效。Telnet 协议默认采用 TCP 23 号端口。

2. Telnet 协议的安全问题及防护措施

Telnet 协议现今并不多用, 许多服务器都禁止了 Telnet 服务。因为在注重安全性的现代网络环境中, 我们不再假设通信网络与通信各方是可信的, 大多数 Telnet 会话都来自不可信的终端, 这些终端与服务器之间的网络也是不可信任的。而工作在上述环境下的 Telnet 协议是一种明文传输协议, 它明文传输用户的通信内容, 包括用户名和密码。因此 Telnet 协议缺乏对数据保密性与完整性的保护, 具体存在以下两类主要安全问题:

(1) 攻击者可以通过嗅探器 (Sniffer) 监听 Telnet 会话, 并记录用户名和口令组合甚至所有会话内容。事实上, 近年来在许多主要 ISP 的主机上都发现存在嗅探器。这些嗅探器捕获 Internet 业务流的成功率相当高, 它们记录 Telnet、FTP 和 rlogin 会话的前 128 个字符, 这足以记录目标主机的地址、登录用户名和口令。

(2) 除了监听 Telnet 会话等被动的攻击方式，攻击者还可以采取主动的攻击方式，比如从通信线路着手劫持 Telnet 会话并在认证完成后篡改或插入一些命令，或者在会话结束后仍然保持已建立的连接。事实上，已经有黑客团体掌握了使用 TCP 劫持工具的方法，他们能够在某种条件下劫持 TCP 会话。对黑客团体而言，Telnet 和 rlogin 会话是极具吸引力的目标。在 Telnet 会话遇到上述的主动攻击时，即使用户没有采用传统的静态口令，而是采用一次性口令（One-Time Password, OTP）或称动态口令的机制（它采用密码学中的 HMAC 算法构造的动态口令，这部分内容将在后续章节中详细讨论）认证登录，也只能避免泄露用户名与静态口令的组合，而不能避免会话被劫持。

对 Telnet 会话进行加密是解决上述安全问题的可行方案。但是，如果通信双方互不信任，单钥加密（在后续章节中会详细介绍）则有害无益，因为通信一方必须将密钥提供给不可信的另一方，这样会泄漏该密钥。目前存在多种 Telnet 的加密解决方案，比如 stel, SSLtelnet, stelnets 和 SSH。虽然也已经出现了对 Telnet 加密的标准化版本，但是尚不清楚有多少用户使用它。而 SSH 已经成为远程登录事实上的标准协议。

3.4.4 SSH 协议

1. 概述

安全壳（Secure Shell, SSH）协议是一种在不安全的网络上建立安全的远程登录或其他安全网络服务的协议，由 IETF 的网络工作小组（Network Working Group）所制定。SSH 是建立在应用层和传输层基础上的安全协议。SSH 设计原意是为了取代原 UNIX 系统上的 rcp, rlogin 和 rsh 等不安全的指令程序，现被用来取代 Telnet 实现安全的远程登录，并可以为 POP, FTP 甚至 PPP 等网络应用程序提供一个安全的“隧道”。SSH 提供多种身份认证和数据加密机制，并采用“挑战/响应”机制替代传统的主机名和口令认证。SSH 对所有传输的数据进行 RSA 公钥加密算法进行处理，避免了如 Telnet 等传统的网络服务程序明文传输口令和数据带来的信息泄露隐患，同时能够有效防止“中间人攻击”（Man-in-the-middle Attack）、DNS 欺骗和 IP 欺骗。SSH 协议默认采用 TCP 22 端口。

SSH 的通信流程主要分为 6 步：建立 TCP 连接、版本协商、算法协商、密钥建立和服务器认证、用户认证、通信会话。

2. SSH 协议的安全问题及防护措施

SSH 协议主要由 3 层协议组成：传输层协议、用户认证协议和连接协议，其中高层协议要运行在底层协议的基础上，因此远程登录过程的安全性是由 3 个安全协议共同保证的。SSH 协议虽然为目前来讲较可靠，专为远程登录会话和其他网络服务提供安全性的协议，但仍有一些安全性问题需要关注，并会面临多种网络攻击。

(1) 服务器认证。SSH 协议主要面向互联网网络中主机之间的互访与信息交换，拥有一套以主机密钥为基础的完备的密钥机制。然而在某些安全性不高的网络环境中，没有可信的认证机构对服务器的真实性进行验证；同时为了用户的客户端使用方便，SSH 协议提供了一个可选功能，即在客户机第一次连接到服务器时，可以不对服务器的主机密钥进行验证。这一功能会产生一些安全问题，虽然此时客户端与服务器之间的通信仍

然是加密的，第三方不可能获得双方通信的内容，但攻击者可能假冒成真正的服务器，从而使得整个系统的安全都受到威胁。因此，在系统中，应尽量避免把该功能设为默认配置，即必须尽可能检验主机密钥，使用验证服务器正确性的方法，例如要求传送 SHA-1 哈希算法生成的主机公钥的 MAC 值等。

(2) 协议版本协商。SSH 协议运行的第一步是进行服务器与客户端协议版本的协商。服务器会打开端口 22 与客户端建立 TCP 连接，之后发送的包含协议版本号的 TCP 报文至客户端，客户端接收报文并解析，之后返回服务器一个包含协议版本号的报文。如果双方的版本号不同，由服务器决定是否可以运行；如果可以，则双方都以较低的版本运行。如果攻击者采用有安全漏洞的版本建立连接，协商的结果是采用有安全漏洞的 SSH 协议版本，则可能会采取进一步的攻击。所以在 SSH 协议软件的配置中需考虑版本问题，对于采用的软件版本有安全问题的通信方，可以采用中断 TCP 连接的办法。SSH 是 Client/Server 结构，并且有两个不兼容的版本，分别是 1.x 和 2.x，其中 1.x 存在许多安全问题，已很少使用。

(3) 主机密钥文件安全。SSH 协议在工作时，服务器的主机密钥存储在一个 root 用户可读的主机密钥文件中，如果该文件被窃取或篡改，则会对协议的认证机制造成严重威胁。攻击者可以利用有效的主机密钥实施一系列攻击，如假冒攻击、重放攻击和中间人攻击等。因此，主机密钥文件必须用非常安全的机制进行管理。

OpenSSH 是 SSH 的替代软件，其源代码是开放的，而且是免费的，且同时支持 SSH 1.x 和 2.x，预计将来会有越来越多的人使用 OpenSSH。现在已经有各种基于 Windows 的 SSH 版本，这些版本的功能和价格各不相同。PuTTY 是一个不错的免费自由软件，该软件不需要安装就可以运行。

3.4.5 DNS 协议

1. 概述

域名系统 (Domain Name System, DNS) 是一个分布式数据库系统，用来实现域名到 IP 地址或 IP 地址到域名的映射。在 Internet 上，域名与 IP 地址之间是一一对应的。域名虽然便于人们记忆，但机器之间只能通过 IP 地址互相识别，它们之间的转换工作称为域名解析，域名解析的工作需要由专门的域名解析服务器来自动完成。域名解析服务器也称作 DNS 服务器，DNS 服务使用的是 53 号端口。

2. DNS 协议的安全问题及防护措施

从安全的角度看，DNS 存在一定的问题。在正常工作模式下，备份服务器可使用“区转移”来获得域名空间中所属信息的完整备份，黑客也常使用这种方式快速获得攻击目标列表。如果将前向命名和后向命名分离，则可能会带来安全问题，黑客若能够掌控部分反向映射树，就能实施欺骗，也就是说，反向记录中可能含有可信赖的那台机器的名称（伪造）。针对 DNS 的攻击还有破坏力更强的变种，攻击者在发起呼叫之前，会扰乱目标机器中 DNS 响应的高速缓存，当目标机器进行交叉检验时，验证结果似乎是成功的，但此时黑客却已经获得了访问权。另外，黑客采用呼叫响应的方式来淹没目标的 DNS 服务器，可使其陷入混乱，此类攻击案例十分常见，黑客只需用非常简单的程序就可以

捣毁 DNS 的高速缓存。

虽然我们无法阻止黑客对 DNS 的不断攻击，但是可以通过采取相应的措施加以控制，如可以对授权的二级服务器限制“区转移”功能的使用。DNSsec 是 DNS 的安全扩展（Domain Name System Security Extensions），由 IETF 提供的一系列 DNS 安全认证机制组成，它可以对 DNS 记录进行数字签名，是消除欺骗性 DNS 记录的最简便的方法。当某个区的所有者有不良动机时，DNSsec 就会签署一个欺骗性的记录，进而可以有效防止此类欺骗。此外，对域的签名可以离线进行，从而降低了域签名私钥泄漏的风险。虽然 DNSsec 对付以上欺骗攻击很有效，但也有一些不足之处，所以它迄今还没有成为主流的 DNS 查询方式。

3.4.6 SMTP 协议

1. 概述

E-mail 是 Internet 上使用最广泛的服务之一。尽管网络上有多重邮件收发服务，但最常用的就是简单邮件传输协议（Simple Mail Transfer Protocol, SMTP）[Klensin 2001]。SMTP 协议属于 TCP/IP 协议族，SMTP 服务使用的是 25 号端口。

传统 SMTP 使用简单的协议传输 7b ASCII 文本字符，SMTP 会话样本日志记录如图 3-4 所示，箭头表明数据的流向。它还有一种扩展形式，称为 ESMTP，允许扩展协商，包括 8b 的传输。这样，它就不不仅能够传输二进制的数，还可以传输非 ASCII 字符集。从图 3-4 中可以看出：远程站点 sales.mymegacorp.com 向本地主机 fg.net 发送了一封电子

```

<--- 220 fg.net SMTP
----> HELO sales.mymegacorp.com
<--- 250 fg.net
----> MAIL FROM: Anthony.Stazzone@sales.mymegacorp.com
<--- 250 OK
----> RCPT TO: <ferd.berfle@fg.net>
<--- 250 OK
----> DATA
<--- 354 Start mail input; end with <CRLF>.<CRLF>
----> From: A.Stazzone@sales.mymegacorp.com
----> To: ferd.berfle@fg.net
----> Date: Thu, 27 Jan 94 21:00:05 EST
---->
----> Meet you for lunch after I buy some power tools.
---->
----> Anthony
---->
<---
<--- 250 OK
----- sales.mymegacorp.com! A.Stazzone sent 273 bytes to fg.net!ferd.berfle
----- QUIT
<--- 221 sales.mymegacorp.com Terminating

```

图 3-4 SMTP 会话样本日志记录

邮件。这是一个简单的协议，网络管理员和黑客都知道如何使用这些命令，他们可以手工输入这些命令。

注意：主叫方在 MAIL FROM 命令中指明了一个返回地址。在这种情况下，本地主机没有可靠的办法来验证该返回地址的正确性。你确实不知道是谁用 SMTP 给你发送了邮件。如果你需要更高的可信度或保密性，就必须使用更高级的安全机制。

一个组织机构至少需要一个邮件服务器。内部网络用户的邮件服务器通常设置在网关上。这样，内部的管理员只须从网关上的邮件服务器上获得他们的邮件。此网关能够保证外出的邮件头部符合标准。如果本地的邮件服务器出现问题，管理员可以方便、及时地解决邮件服务器故障。

通过采用邮件网关，公司内部的所有人都有一个单独设立的邮箱。但是这些邮件账户列表必须严加保护，以防被人窃取而成为黑客攻击的目标。

2. SMTP 协议的安全问题及防护措施

从安全的角度看，基本的 SMTP 自身是完全无害的，但是它可能成为拒绝服务攻击的发源地。攻击者可以采用拒绝服务攻击阻止用户合法使用该邮件服务器。假设攻击者能控制 50 台机器，每台机器都向邮件服务器发送 1000 个 1MB 大小的邮件，恐怕邮件系统很难处理数量如此之多的邮件。

邮件的别名有时也会给黑客提供一些有用的信息。像下面的一些命令

```
VRFY <postmaster>
```

```
VRFY <root>
```

通常可以把邮件别名翻译成实际的登录名称。它可能提供一些关于谁是系统管理员、攻击成功后哪个账户最有价值等线索。这些信息是敏感的还是不敏感的，完全是安全策略问题。

EXPN 子命令扩展了邮件列表的别名。这个命令存在很大的问题，这可能会导致机密性的丧失。要避免这种风险，一种有用的做法是将暴露的邮件服务器主机的别名指向一台内部的机器，这台机器从外部是不可达的，从而消除这种扩展所带来的风险。

不管运行何种邮件服务程序，应该将其配置成仅接受那些要么来自你的网络中的邮件，要么是那些发给你的用户的邮件。所谓的“开放中继”（Open Relay）就是允许在任何人之间进行邮件传递，这是非常危险的。许多网站都拒绝接收那些来自自己“开放中继”的电子邮件。

SMTP 攻击者（spammer）寻找 SMTP 服务器是为了传递他们的 spam（垃圾邮件）。他们需要连接到高带宽的 E-mail 服务器上，将简单的信息传递到不同的地址。SMTP 服务（尤其是 Sendmail）是入侵系统的最常用方法之一，因为它们必须完整地暴露于 Internet，且邮件的路由是复杂的（暴露+复杂=弱点）。

如果想支持移动用户，可以使用 SMTP 认证。它最好与加密 SMTP 会话结合起来使用[Hoffman 2002]。SMTP 认证的主要目的是要避免“开放中继”的存在。因为“开放中继”能吸引 spammer，并导致在网站上添加一条 reject all mail from this clowns 信息。这

种 SMTP 的用法有时被称为“邮件托付”（Mail Submission），以便与更通用的邮件传输相区别。

3.4.7 MIME 协议

1. 概述

多用途网际邮件扩充协议（Multipurpose Internet E-mail Extension, MIME）最早于 1992 年就应用于电子邮件系统，后来也用于浏览器。服务器通过说明发送的多媒体数据的 MIME 类型，来告诉浏览器该多媒体数据的类型，从而让浏览器知道接收到的哪些信息是 MP3 文件，哪些是 Shockwave 文件等。

2. MIME 协议的安全问题及防护措施

当 MIME 应用于浏览器时，浏览器收到文件后，会进入插件系统进行查找，查出哪种插件可以识别并打开收到的文件。如果浏览器不确定调用哪种插件系统，它可能会告诉用户缺少某插件，或者直接选择现有的某个插件来尝试打开收到的文件。传输的信息中缺少 MIME 标识可能导致的情况很难估计，因为某些计算机系统可能不会出现故障，但某些计算机系统可能会因此崩溃。

当 MIME 应用于电子邮件系统时，撇开邮件客户端软件的缺陷不谈，自动运行 MIME 编码消息就潜藏着巨大的风险，因为这些消息中被编码的结构信息能够指示客户端软件要采取何种行动。

对于 MIME 还存在一种分段攻击。有一种 MIME 类型，它允许将单个电子邮件消息分成几段。如果消息的分段做得很巧妙，就可以用来逃避基于网关的病毒检测。当然，如果邮件客户端软件不能重组这些分段的消息，这种攻击也是无效的，然而微软的 Outlook Express 确实可以重组这些分段的消息。解决这个问题有两种方法，一是在网关上重组这些消息，二是拒绝那些分段发来的邮件。

MIME 存在的其他风险包括邮寄可执行程序 and 含有危险动作的 PostScript 文件。通过电子邮件发送可执行程序是传播蠕虫和病毒的主要根源。当然，攻击者也可能通过电子邮件发送一条含有伪造的“From:”命令行的 MIME 消息。许多流行的蠕虫和病毒就是采用这种方式传播的。

上述这些问题和其他一些安全问题在 MIME 技术文档中已有详细说明。但是，很多基于 Windows 系统的邮件服务器几乎都忽视了这些建议。

3.4.8 POP3 协议

1. 概述

邮局协议（Post Office Protocol, POP）是一个邮件接收协议，它的第 3 个版本称为 POP3。它规定了如何将个人计算机连接到遵循 POP3 协议的接收邮件服务器并下载电子邮件，是 Internet 电子邮件的第一个离线协议标准。其具体过程是：电子邮件发送到邮件服务器，客户机通过邮件客户端软件连接服务器，并下载所有未阅读的电子邮件，同时删除保存在邮件服务器上的邮件（目前很多 POP3 服务器在邮件被下载后，并不删除

邮件)。当客户机长时间保持在线时,邮件客户端软件会每隔一定的时间就获取一次新的邮件。POP3 服务允许用户设置本地浏览器的接收/发送邮件服务器名称,客户机采用 POP3 和 SMTP,用同一个或不同的邮件服务器来收发电子邮件。在 TCP/IP 中,POP3 服务采用的 TCP 端口号为 110。

2. POP3 协议的安全问题及防护措施

POP3 非常简单,服务器可用 Perl 脚本程序非常容易地实现它。正是因为它简单,所以它也非常不安全。在使用 USER/PASS 组合的旧版本中,用户在访问邮箱时采用的口令是以明文传输的,攻击者很容易窃取到用户名和口令,从而获取用户邮箱中的所有邮件。最近开发的邮件客户端软件采用 APOP 命令来收取邮件,以安全地传输用户口令。APOP 基于口令认证中常用的“挑战/响应”机制,对用户名和口令进行加密。但 APOP 对邮件内容不作保护,即使得不到用户名和口令,攻击者也很容易窃取到以明文形式传输的邮件内容。以上两种协议均将口令以明文形式存储在服务器上,一旦服务器遭到攻击,则可能造成用户名和口令的泄露。此外,攻击者也可能对认证交换的口令发起字典攻击。为保障邮件安全传输,可以利用 SSL/TLS 协议对传输的数据进行加密。目前,很多站点支持基于 SSL/TLS 的 POP3 服务,但有些客户端不支持这一服务。

如果邮件服务器运行的是 UNIX 操作系统,那么 POP3 服务器软件在认证结束前通常以 root 用户权限运行,用户必须在服务器上开设一个账号。其实这很不利:一方面它增加了邮件服务器的管理难度,另一方面意味着用户可以登录到邮件服务器上。这种设计思想非常危险,因为用户可能给服务器带来非常大的安全风险。尽管如此,仍然可以使用 POP3 服务器收发邮件,但要保证 POP3 服务器仅对其用户数据库和电子邮件进行维护。

3.4.9 IMAP4 协议

1. 概述

Internet 消息访问协议(Internet Message Access Protocol, IMAP)是由美国华盛顿大学所研发的一种邮件获取协议,当前的权威定义是 RFC3501。它的主要作用是邮件客户端(如 MS Outlook Express)可以通过这种协议从邮件服务器上获取邮件的信息并下载邮件。正如 POP3 是 POP 的第 3 个版本一样,IMAP4 是 IMAP 的第 4 个版本,它提供了同 POP3 一样方便的邮件下载服务,而且在对邮箱的访问控制功能上比 POP3 更加强大。IMAP4 运行在 TCP/IP 之上,使用的端口号是 143。

IMAP4 同样提供了方便的邮件下载服务,让用户能进行离线阅读,但 IMAP4 还有其他一些功能。首先,IMAP4 提供的摘要浏览功能可让用户在阅读完所有邮件的到达时间、主题、发件人、大小等信息后才做出是否下载的决定;其次,用户还可以享受选择性下载附件服务。例如一封邮件里含有 5 个附件,用户可以选择下载其中的两个附件;第三,在支持离线阅读的同时,IMAP4 既允许用户把邮件存储和组织在服务器上,也允许用户把邮箱作为信息存储工具。

IMAP4 协议适用于 C/S 构架中,IMAP4 协议是对提供邮件访问服务且使用广泛的

POP3 协议的另一种选择，基本上两者都是规定个人计算机如何连接到互联网上的邮件服务器进行收发邮件。IMAP4 协议支持对服务器上的邮件进行扩展性操作，IMAP4 也支持 ASCII 码明文传输密码。

与 POP3 不同的是，IMAP4 能支持离线和在线两种模式来传输数据：①在离线方式中，客户端程序会不间断地连接服务器下载未阅读过的邮件到本地磁盘，当客户端需要接收或者发送邮件时才会与服务器建立连接，这就是离线访问模式。POP3 典型地以离线方式工作。②在线模式中，一直都是由客户端程序来操作服务器上的邮件，不需要像离线模式那样把邮件下载到本地才能阅读（即使用户把邮件下载到本地，服务器上也会保存一份副本，而不会像 POP 协议那样把邮件删除）。用户可以通过客户端程序或者 Web 在线浏览邮件。一些 POP3 服务器也提供了在线功能，但是，它们没有达到 IMAP4 的浏览功能的级别。

IMAP4 是分布式存储邮件方式，本地磁盘上的邮件状态和服务器上的邮件状态，可能和以后再连接时不一样。此时，IMAP4 的分布式存储机制解决了这个问题。IMAP4 邮件的客户端软件能够记录用户在本地地的操作，当连上网络后会把这些操作传送给服务器。当用户离线的时候服务器端发生的事件，服务器也会告诉客户端软件，比如有新邮件到达等，以保持服务器和客户端的同步。

IMAP4 协议处理线程都处于 4 种处理状态的其中一种。大部分的 IMAP4 命令都只会在某种处理状态下才有效。如果 IMAP4 客户端软件企图在不恰当的状态下发送命令，则服务器将返回协议错误的失败信息，如 BAD 或 NO 等。

总的来说，IMAP4 同时兼顾 POP3 和 WebMail 的优点，是当前一种较好的通信协议。目前支持 IMAP4 的免费邮件系统并不多，较常见的有 777 免费电子邮箱（<http://mail.777.net.cn>）等。

IMAP4 使用户可以对服务器上的邮箱进行远程访问。它可以使客户机和服务器的状态同步，并支持多重文件夹。如同 POP3 一样，邮件仍然通过 SMTP 发送。

典型的 UNIX IMAP4 服务器提供了与 POP3 服务器相同的访问方式，同时还增加了许多功能。虽然 POP3 服务器已能满足用户的需求，但是 IMAP4 服务器的应用也很有潜力。

2. IMAP4 协议的安全问题及防护措施

IMAP4 能够支持一些认证方法，并且有些方法非常安全。前面提到的“挑战/响应”机制很有用，但是它并没有达到人们预期的安全性。在“挑战/响应”机制中使用了一个共享的秘密，这个秘密信息必须存储在服务器上。如果将该秘密与域字符串进行杂凑运算，这对消除口令的等值性可能会更有利。

对于 IMAP4 来说，最大的牺牲是协议的复杂度太高，它当然也需要一个更复杂的服务器。如果该服务器能够采用小而简单的认证模块恰当地实现，认证的安全性将会得到保障。但是，这需要对服务器的设计进行验证。

3.4.10 PGP 协议

1. 概述

PGP (Pretty Good Privacy) 协议是常用的安全电子邮件标准之一。1991 年, Phil Zimmermann 提出 PGP, 可用于文本、E-mail、文件或整个磁盘分区的签署或加密, 也可用于提高 E-mail 通信的安全性。PGP 安全体制包括 5 种服务: 认证、保密、压缩、电子邮件兼容性和分段。详细描述见表 3-2。

表 3-2 PGP 服务概述

功 能	使用算法	描 述
数字签名	DSS/SHA 或 RSA/SHA	消息的 Hash 码利用 SHA-1 产生, 将此消息摘要和消息一起用发送方的私钥按 DSS 或 RSA 加密
消息加密	CAST 或 IDEA, 或使用 3DES 或 RSA	将消息用发送方生成的一次性会话密钥按 CAST-128 或 IDEA 或 3DES 加密。用接收方公钥按 Diffie-Hellman 或 RSA 算法加密会话密钥, 并与消息一起加密
压缩	ZIP	消息在传送或存储时可用 ZIP 压缩
电子邮件兼容性	基数 64 转换	为了对电子邮件应用提供透明性, 一个加密消息可以用基数 64 转换为 ASCII 串
分段	——	为了符合最大消息尺寸限制,PGP 执行分段和重新组装

2. PGP 协议的安全问题及防护措施

PGP 安全电子邮件能解决邮件的加密传输问题, 验证发送者的身份验证问题, 错发用户的收件无效问题, 因而得到广泛应用。但 PGP 仍然存在一些安全问题。

(1) PGP 存在公钥篡改的安全问题。随着 PGP 的普及, 多用户系统上也出现了 PGP, 这样暴露明文和密钥或口令的可能性增大, 公钥篡改将导致使用的公钥与公钥持有人的公钥不一致, 使得合法通信者无法解密文件或其敌手可以伪造签名。所以, 当用户使用别人的公匙时, 需要保证它是直接从对方处得来或是由另一个可信的人签名认证过的。同时, 用户要保持对自己密钥环文件的物理控制权, 确信没有人可以篡改自己的公匙环文件。

(2) PGP 签名上的时间戳不可信。任何想伪造一个“错误”时间戳的人都可以通过修改系统时间达到目的。而在商业上有利用 PGP 签名的时间来确认责任的需要, 因此有必要建立第三方的时间公证体系, 由公证方在邮件上签上标准的时间, 来解决 PGP 时间戳不可靠的问题。目前, 对时间可靠性有要求的场合, 用户可以采用国际标准时间戳协议 RFC3161 来解决。

(3) PGP 的信任模型存在缺陷。为从陌生人那里得到有效的公钥证书, PGP 中引入了介绍人, 却同时带来了信任问题。因为在 PGP 中, 用户没有任何依据来判断一个人的信任等级, 只能通过直觉来对一个用户的信任度进行设置, 如果设置不当就会造成安全隐患。另外, PGP 缺乏有效的证书管理体系。证书为保证公钥的真实性提供了一种有效机制, 而在 PGP 中证书的管理完全由用户自己来完成, 错误的信任假设和管理的不当,

会影响到 PGP 的安全性。PGP 中虽然提供了吊销证书的功能，却没有提供任何将吊销信息通知其他用户的方式，用户使用被吊销的证书是件很危险的事情，很有可能造成泄密。

3.4.11 FTP 协议

1. 概述

文件传输协议（File Transfer Protocol, FTP）是 TCP/IP 协议族中的重要协议之一，它是 Internet 文件传送的基础。简单地说，FTP 就是完成两台计算机之间的复制。若将文件从远程计算机复制到本地的计算机，称为“下载”（download）文件；反之，则称为“上传（upload）”文件。FTP 标准命令采用的 TCP 端口号为 21，Port 方式数据端口为 20。

客户机首先使用 FTP 命令打开一条通往服务器的控制通道。然后，服务器与客户机之间可以通过两种模式打开数据通道。在主动（Port）模式中，客户机通过 PORT 命令将一个随机的端口号通知服务器，服务器随后通过 20 号端口呼叫客户机的指定端口建立数据连接。在被动（PASV）模式中，客户机向服务器发送一条 PASV 命令，服务器随机选择一个端口号并通知客户机，从而建立数据连接。

2. FTP 协议的安全问题及防护措施

（1）使用 PORT 命令会引起一系列安全问题。首先，主动模式是由服务器主动对客户机进行连接。一旦这个连接受到黑客的攻击，那么防火墙无法对其作出正确的处理。其次，使用 PORT 命令还可能引起 FTP 反弹攻击（FTP Bounce Attack）。由于客户机在 PORT 命令中发送了自己的 IP 和端口号，攻击者能够对该客户机的端口进行扫描。采用这种攻击方式，攻击者能够打开一条通往任意一台机器的通道。

（2）攻击者可以将 Java 程序伪装成 FTP 客户机从而发动攻击。例如，假设攻击者希望连接到防火墙后面某台机器的 Telnet 端口，那么他会设法将这个 Java 程序嵌入到目标 Web 页面文件中。当有人在该站点上运行此 Java 程序时，它就会打开一条通往 Web 页面的 FTP 连接。只要伪装的 FTP 客户机发出一条 PORT 命令，指明采用 23 号端口 Telnet 到目标主机上，此时防火墙就会打开该端口。

（3）访问 FTP 服务器要使用口令登录，但是该口令能够很容易地被探测或猜测到。在运行 FTP 协议时，客户机与服务器之间的消息（包括口令）是以明文的形式传输的，这就导致了泄露口令的风险。

（4）在 ftpd 守护程序中，历史上存在很多缺陷，而这些缺陷可能导致严重的安全漏洞。例如，ftpd 守护程序开始时以 root 用户权限运行，但它不能在登录后掩盖其特权用户身份。

对于以上安全问题，可以采取一些防护措施。为了避免使用 PORT 命令造成的安全问题，现在，Internet 上大多数的 FTP 服务器和主流浏览器都支持 PASV 命令。如果 FTP 使用 PASV 命令，那么在配置防火墙的安全措施时，就可以禁止所有进入的 TCP 连接。除此之外，为了防止泄露口令，可以使用密文来传输用户名和口令。

3.4.12 TFTP 协议

1. 概述

简单文件传输协议（Trivial File Transfer Protocol, TFTP）是用来在客户机与服务器之间进行简单文件传输的协议，提供不复杂、开销不大的文件传输服务。TFTP 承载在 UDP 上，提供不可靠的数据流传输服务，不提供存取授权与认证机制，使用超时重传方式来保证数据的到达。与 FTP 相比，TFTP 要小得多。现在最普遍使用的是第 2 版 TFTP（TFTP Version 2, RFC 1350）。TFTP 服务使用 UDP 69 端口。

2. TFTP 协议的安全问题及防护措施

TFTP 协议比较简单，因为它只提供文件传输而不能验证文件是否成功传送。由于在可靠性与安全性上没有保证，所以它的应用没有像 FTP 一样普及。不过由于它不用消耗太多的网络资源用于传输数据，所以 TFTP 常用于一些对连接的安全性要求不高的场合。它常用于启动路由器、无盘工作站、X11 终端和嵌入式设备等。适当配置 TFTP 守护程序，可以限制客户端只能访问服务器端的一个或两个目录，这两个目录通常为 `usr/local/boot` 和 `X11` 字库。但在过去，许多厂商发布的 TFTP 软件并不限制访问服务器端的任何目录，黑客能轻易地利用它从事非法活动。下面就是黑客实施口令破解攻击的一个实例。

```
$ tftp target.cs.boofhead.edu
tftp> get /etc/passwd /tmp/passwd
Received 1205 bytes in 0.5 seconds
Tftp> quit
$crack </tmp/passwd
```

我们知道，现在网络上存在很多用来进行口令破解的“字典”。如果采用一个普通字典猜对口令的概率是 25%，那么攻击者就很容易攻破一台机器。同时，与该机器相连的其他机器也难逃厄运。因此，除非真的需要此协议，否则不应该在任何机器上运行该协议。如果所使用的机器上确实已经安装了此协议，则应确保对它进行正确配置，只允许那些符合访问控制策略的文件进行传送。很多路由器（特别是低端的路由器）都使用 TFTP 上传可执行的映像文件或配置文件。上传配置文件特别危险，因为精明的黑客可能上传伪造的文件（即使伪造文件很困难），并通过配置文件中所包含的口令对系统发起攻击。因为 TFTP 的安全问题，所以即使用 TFTP 也往往只开放其下载权限而不分配上传权限。

3.4.13 NFS 协议

1. 概述

NFS（Network File System）即网络文件系统，是一个基于 TCP/IP 网络的文件共享协议。NFS 协议允许一个系统在网络上与他人共享目录和文件。通过使用 NFS 协议，用户和程序可以像访问本地文件一样访问远端系统上的文件，在远端系统的共享磁盘上进

行诸如修改、删除和创建文件操作。NFS 协议采用基于远程过程调用（RPC）的分布式文件系统结构，客户机可以很方便地请求服务器系统的远程执行。目前，RPC 已经得到很多操作系统的支持，包括 Solaris，Linux 及 Microsoft Windows。

2. NFS 协议的安全问题及防护措施

（1）NFS 没有用户验证机制，只验证 RPC/Mount（句柄加载）请求。NFS 协议采用的基本工具是文件句柄。文件句柄是一个能够识别磁盘上所有文件和目录的独特字符串。所有的 NFS 请求都使用文件句柄、操作和与此操作有关的一些参数加以描述。大多数文件句柄中还包含一个随机数，由伪随机数生成器产生（有些旧版本的 NFS 所使用的随机数的随机性不足，因此种子密钥是可预测的）。文件系统根目录（Root Directory）的初始句柄在加载（mount）时获得。任意一台持有根文件句柄的客户机都具有访问该文件系统的永久权限，然而服务器并没有对每次操作都强制验证客户端的访问控制权限。因此，NFS 这种基于加载的访问控制是非常不恰当的。

（2）NFS 服务器使用的 2049 端口号在选择上存在问题。该端口号处于“无特权的”范围内，而该范围的端口一般应该分配给那些普通的进程。因此，必须对包过滤器做适当配置，以阻止 UDP 会话访问 2049 号端口。还有些版本的 NFS 使用了随机的端口，采用 rpcbind 提供地址信息。

（3）NFS 恶意客户机可对服务器实施拒绝服务攻击。某个具有访问服务器优先权或能伪造返回数据包的客户机，有可能创建一个 setuid 程序或创建一个设备文件。它会不停地取消或打开它与服务器的连接，从而影响到其他客户机对服务器的正常访问。有些 NFS 客户端含有禁止这种行为的选项。如果你的客户机从不可信的资源加载了文件系统，切记要利用这些选项。

（4）NFS 服务器可对客户机植入可以程序。通过 NFS 浏览文档时，会出现一个更加敏感的问题。对于服务器来说，要在客户机上植入某种恶意的程序（如 ls）非常容易，这种程序很可能用于某些非法操作。对于客户机来说，最佳的防护是对所有外来的文件进行检查，删除那些可执行的代码。

3.4.14 SNMP 协议

1. 概述

简单网络管理协议（Simple Network Management Protocol，SNMP）是为了解决 Internet 上的路由管理问题而提出，被应用于支持网络管理系统，以监测连接到网络上的设备是否有任何引起管理上关注的情况。简单网络管理协议模型由 4 部分组成：管理节点、管理站、管理信息库和管理协议。SNMP 协议的应用范围非常广泛，被应用于诸多种类的网络设备、软件和系统中，并被认为是网络设备厂商、应用软件开发及终端用户的首选管理协议。SNMP 的主要作用是控制路由器、网桥及其他网络单元，用来读/写各种设备信息，如操作系统、版本、路由表、默认的 TTL、流量统计、接口名称和 ARP 映射表等，其中有些信息是非常敏感的。例如，出于商业原因，许多 ISP 会对其流量统计信息严加保护。

2. SNMP 协议的安全问题及防护措施

SNMP 协议已有 3 个版本, 分别为 SNMPv1、v2、v3。SNMPv1、v2 的安全性问题主要为:

(1) SNMPv1、v2 中, 因其代理可被多个管理站管理, 被管设备鉴别管理站合法性是通过团体名和源地址检查实现的, 团体名为固定长度字符串, 因而容易被攻击者采用穷举等办法破解;

(2) SNMP 数据被封装在 UDP 中传输, 攻击者通过嗅探监听, 捕获管理站与被管设备之间交互信息, 即可获得 SNMP 消息中的明文团体名;

(3) 攻击者通过嗅探监听截获管理站发往被管系统的管理消息后, 通过对消息数据恶意重组、延迟和重放即可实现对被管设备的攻击^[1]。

与 SNMP v1、v2 相比, SNMP v3 具有更高的安全性, 如增加了密码学的认证方式, 可选择加密算法。最重要的是, 它给不同用户授予了访问 MIB 的不同权限。但采用密码认证可能要耗费系统资源, 而路由器 CPU 的计算能力通常比较弱, 也带来了很大制约。

SNMPv1、v2 由于缺少鉴别和加密机制, 通常采用如下防护措施:

(1) 在不必要情况下关闭 SNMP 代理, 不提供 SNMP 服务^{[2][3]};

(2) 修改设备缺失的团体名, 设置为相对复杂的 SNMP 团体名;

(3) 管理站 IP 地址限定, 只有 SNMP 管理站的 IP 地址可以发起 SNMP 请求;

(4) 设置访问控制, 限制被管设备利用 TFTP, FTP 和 RCP 等方式下载上传文件。

SNMPv3 的认证和加密机制完善, 攻击者难以通过截取数据包获取信息, 或进行加工重放攻击, 安全性较好。但大量的加解密运算会占用大量的 CPU 和内存, 使其推广使用受到限制。

3.4.15 DHCP 协议

1. 概述

动态主机配置协议 (Dynamic Host Configuration Protocol, DHCP) 用来分配 IP 地址, 并提供启动计算机 (或唤醒一个新网络) 的其他信息。处于启动状态的客户机发送 UDP 广播数据包, 服务器会对查询做出响应。这些查询信息可以使用中继程序向前传递到其他网络。服务器会给主机分配一个固定的 IP 地址。

DHCP 提供了一种动态指定 IP 地址和配置参数的机制, 这主要用于大型网络环境和配置比较困难的情况。DHCP 的配置参数使得网络上的计算机通信变得方便且容易实现。DHCP 使用户可以租用 IP 地址, 对于拥有成百上千台计算机的大型网络来说, 每台计算机拥有一个 IP 地址有时是不必要的。IP 地址采用“租约”的方式, 租期从 1 分钟到 100 年不定。当租期已满时, 服务器可以把这个 IP 地址分配给其他机器使用。当然, 客户也可以请求使用自己喜欢的网络地址及相应的配置参数。

DHCP 能够提供大量的信息——域名服务器地址、默认的路由地址、默认的域名及客户机的 IP 地址, 许多应用都将使用这些信息。它还可以提供其他一些设备地址, 如网络时间服务器的地址等。

DHCP 服务器能对 IP 地址提供集中化的管理, 简化了管理任务。动态 IP 地址分配

仅保留了有限的 IP 地址使用空间。它可以很容易地为便携式计算机分配 IP 地址。例如，人们在咖啡馆或机场候机厅无线上网时，就必须使用这个协议。

2. NTP 协议的安全问题及防护措施

处于安全性的考虑，此协议只能在本地网络上使用。这是因为，启动状态的主机尚不知道自身的 IP 地址，所以 DHCP 服务器必须将查询响应传送到它的第二层地址，即它的以太网地址。要做到这一点，DHCP 服务器要么在自己的 ARP 表添加一个映射，要么发送一个纯第二层的数据包给客户机。总之，DHCP 服务器和客户机均需要直接接入本地网络。由于远程的攻击者无法接入本地网络，因此也无法对 DHCP 服务器发起远程攻击。

由于 DHCP 服务器通常没有对查询信息进行认证，所以查询响应容易受到中间人攻击和拒绝服务（DoS）攻击。但是，如果攻击者已经接入到本地网络，那么他就可以发动 ARP 欺骗攻击。既然远程攻击者接入到本地网络的可能性不大，这就意味着运行 DHCP 带来的风险并不大。当 DHCP 服务器与 DNS 服务器接口时，需要建立一条从 DHCP 服务器到 DNS 服务器的安全连接，这通常采用对称密钥加密算法生成 SIG 签名记录来实现。考虑到 DHCP 客户端的 IP 地址包含在 DHCP 审核记录日志里，这就提供了对拒绝服务攻击源进行跟踪的能力。因此，DHCP 日志可以用作法庭上的重要证据。在进行 IP 地址动态分配的时候，需要知道在某个给定的时刻，哪个硬件设备使用了哪个 IP 地址，而日志中所记录的以太网地址是非常有用的。当计算机犯罪事件发生时，网警将会设法取得 ISP 的 DHCP 日志进行分析，并取得相应的以太网地址。

此外，攻击者可用假冒的 DHCP 服务器压制合法的 DHCP 服务器，对查询提供响应并导致各种类型的攻击。这些假冒的服务器会模仿不同的以太网地址向合法的服务器发出大量请求。合法的服务器就会被这些查询请求淹没，全部可用的 IP 地址会被消耗殆尽。所以，需要确保未经授权的人员没有对网络进行物理访问或无线访问的权限，限制管理组的成员身份，将管理服务器所必需的用户减少到最小数量。

3.4.16 H.323 协议

1. 概述

H.323 是由 ITU-T 于 1996 年提出的用于 VoIP（Voice over Internet Protocol，俗称 IP 电话）的一套标准，为分组网提供实时音频、视频和数据通信的标准，为语音通信、视频通信、传真及其他数据业务提供支持。该标准详细描述了用于包交换网络的多媒体通信系统及其组成单元，并规定了各单元之间的通信过程。由于 H.323 标准的工作方式符合 VoIP 技术的要求和标准，并具有灵活性高、兼容性好、资源需求少等优势，已逐步发展为目前在分组网上支持语音、图像和数据业务最成熟、应用最广泛的 VoIP 标准。

2. H.323 协议的安全问题及防护措施

虽然基于 H.323 标准的 VoIP 产品在互联网上得到广泛应用，但是其在安全性方面却存在不少隐患。由于 H.323 会话的建立需要经过若干步骤，由各个组件相互配合共同完成，因此在其通信的某些阶段留下安全隐患。另外，考虑到 H.323 产品组件具体实现的

不同,其所拥有的系统资源、处理错误输入的机制也有所不同,也导致了某些安全问题。目前 H.323 的主要安全隐患有拒绝服务、注册劫持和会话中断等。

(1) 拒绝服务。在 H.323 产品的通信过程中,需要终端开放特定端口时刻处于监听状态,因此给拒绝服务攻击创造了条件,恶意用户可向某一目标终端大量、密集地发送数据包,导致该终端的资源耗尽而无法响应其他合法用户。

(2) 注册劫持。攻击者在终端注册环节抓包截取被冒用用户的标识信息,再向网关发送“取消注册”消息解除合法用户的注册,最后使用窃取到的标识信息向网关进行注册,冒用该用户的身份。

(3) 会话中断。由于终端之间用于会话控制和管理的相关指令以明文传送,并且不对消息的来源进行过多的确认,因此攻击者可以通过抓包获取终端标识及其他有用信息,填入自己伪造的结束会话命令构造攻击数据包,强制中断合法用户的会话。

为保证 H.323 的安全性,ITU-T 提出了 H.325 建议,为协议制订了认证、保密性和完整性的安全体系。如通过口令和对称加密认证算法来进行身份认证和完整性检查,通过 IPSec 安全隧道保证呼叫信令安全,使用协商的密钥进行加密,避免语言窃听和语音干扰等。

3.4.17 SIP 协议

1. 概述

会话启动协议(Session Initiation Protocol, SIP)是一个复杂通信协议,它是由 IETF 制定的基于文本编码的多媒体通信协议。会话主叫方使用 SIP 协议定位 IP 网络上的被叫方,用于建立、修改并终止一个或多个参与者的多媒体会话。它使用户的通信系统更加开放,使用更加便捷,选择更加多样,也更为个性化。

SIP 虽然很复杂,但与 H.323 相比却要简单得多。它采用 ASCII 对消息编码,语法上很像 HTTP。它甚至可以使用 MIME 和 S/MIME 数据类型进行数据传输。

SIP 电话可以是实体到实体(peer-to-peer)的,但它也有像 H.323 一样的代理程序。尽管实际的数据直接在两个(或多个)端点之间传输,但这些代理可以简化 SIP 电话穿过防火墙的进程。SIP 也提供了很强的安全性,也许正因为安全性太好,在某些情况下,它会对应用级网关防火墙重写消息造成干扰,使语音数据流不容易穿过应用级网关防火墙。

2. SIP 协议的安全问题及防护措施

SIP 实体主要由 4 部分组成: SIP 用户代理(User Agent, UA)、SIP 注册服务器(Register Server)、SIP 代理服务器(Proxy Server)和 SIP 重定向服务器(Redirect Server)。由于 SIP 协议采用文本形式表示消息的词法和语法,对文本形式的分析比较简单,使得 SIP 会话容易遭受安全问题,包括欺骗、会话截获和窃听等问题。目前, SIP 协议存在的安全隐患主要有以下几方面。

(1) 注册劫持。当用户在终端将自己的信息注册到某个注册服务器上,注册服务器可根据字段找到该用户地址,并从 From 字段确定消息能否修改用户的注册地址。但 From 字段有可能被 UA 拥有者修改,使得恶意修改注册信息成为可能。

(2) 伪装服务器。恶意攻击者将自己伪装成远端服务器，使得用户代理终端 UA 错误地被截获。

(3) 篡改消息。篡改消息分为篡改 SIP 消息体和篡改 SIP 消息头字段两种。篡改 SIP 消息体是指攻击者修改 SIP 消息的加密密钥，一旦注册服务器有恶意存在，就可以像中间人一样修改会话密钥，从而破坏原始请求 UA 安全。同时，为了保护一些重要的 SIP 消息头字段，UA 要加密 SIP 包体，并对端到端之间的头字段做限制，防止攻击者的篡改。

(4) 恶意修改或结束对话。攻击者伪造 BYE 请求结束对话，使得会话被提前结束。

(5) 拒绝服务。攻击者通过转发网路通讯堵塞网络接口，使得某个特定的网络节点不能正常工作。

针对以上的安全隐患，SIP 协议制定了安全策略以保证信息的保密性和完整性。

(1) 网络层和传输层的安全保护。利用网络层 IPSec、传输层 TLS 等加密 SIP 消息，传输过程中通过 TLS 套接口，保证消息的可靠性和机密性。

(2) HTTP 摘要认证。SIP 协议常采用 HTTP 摘要认证机制完成身份的认证，HTTP 摘要认证可由唯一确定的用户名及密码认证一个用户，其认证机制主要有 Proxy-to-User 和 User-to-User 两种模式。

(3) 应用层端到端加密。SIP 协议利用 PGP 加密方式和 S/MIME 加密方式来完成应用层端到端的加密，实现数字签名、鉴别以及保密的功能。

3.4.18 NTP 协议

1. 概述

网络时间协议（Network Time Protocol, NTP）是用来在分布式时间服务器和客户端之间进行时间同步，使网络内所有设备的时钟保持一致，从而使设备能够提供基于统一时间的多种应用。NTP 基于 UDP 报文进行传输，使用的 UDP 端口号为 123。该协议是依然运行在当前网络环境中最古老的协议之一，截至 2016 年，协议最新的版本 NTPv4 已经被收录在 RFC 5905 中。

NTP 主要应用于需要网络中所有设备时钟保持一致的场合，例如：

(1) 在网络管理中，对于从不同设备采集来的日志信息、调试信息进行分析的时候，需要一个统一的时间作为参照依据。

(2) 计费系统要求所有设备的时钟保持一致。

(3) 定时重启网络中的所有设备时，要求所有设备的时钟保持一致。

(4) 多个系统协同处理同一个比较复杂的事件时，为保证正确的执行顺序，多个系统必须参考同一时钟。

(5) 在备份服务器和客户端之间进行增量备份时，要求备份服务器和所有客户端之间的时钟保持一致。

2. NTP 协议的安全问题及防护措施

NTP 协议是横跨多系统平台的基础网络协议，NTP 协议的安全对系统应用的安全有着重要的影响。一旦 NTP 服务失效，需要时间同步的相应系统服务都会失败。因此 NTP

服务器自身可能成为各种攻击的目标。一旦 NTP 服务器受到攻击,通过该服务器获取时间同步的系统应用都会受到影响。除此之外,NTP 也常常作为其他网络攻击手段的重要辅助手段之一。常见的攻击手段有以下几种:

(1) 针对 TLS/SSL 协议,攻击者会考虑利用 NTP 协议,修改被攻击者的系统时间,以此将过期证书或已撤销证书变为有效证书,达到欺骗目的。

(2) 针对 DNS 服务器,攻击者利用 NTP 协议,修改被攻击设备的系统时间,造成所有连接 DNSSEC 服务器的用户密钥和签名失效,破坏 DNS 服务。除此之外,针对 DNS 服务器缓存存储域名的时间周期为 24 小时的特点,通过大范围的 NTP 失效迫使大量 DNS 服务器同时刷新缓存,引发网络洪泛攻击。

(3) 针对认证服务,通常认证服务需要认证信息携带时间戳以防止重放攻击,然而利用 NTP 协议攻击,能够绕过时间戳检验,达到发动重放攻击的目的。

(4) 利用 NTP 服务器收到 monlist 请求后最多会返回 100 个响应包的特性,攻击者伪造受害主机的 IP 地址向 NTP 服务器不断发送 monlist 请求,以此利用 NTP 服务器向受害主机返回大量的数据包从而造成其网络拥塞,达到 DDoS 攻击特定目标的目的。

为了抵御这些攻击,新版本的 NTP 服务器软件能采用密码技术对消息进行认证,以减少 NTP 协议被非法利用的可能性。尽管这一功能非常有用,但所达到的效果却不尽如人意。攻击者即使不能与 NTP 守护程序直接对话,仍然可以扰乱服务器的守护程序以阻止获取正确的时钟。换言之,要达到安全的目的,NTP 服务器就必须对本地时间源到其他时间源直至根时间源的连接加以认证。管理员也应该合理配置 NTP 守护程序,以拒绝那些来自外部的跟踪请求。

3.4.19 FINGER 协议

1. 概述

Finger 协议最早出现在 BSD3.0 系统中,端口号为 79,是互联网上最老的协议之一。后来很多 UNIX 系统使用了这个协议,fedora core 3 系统也有 Finger 的客户端,但是 fedora core 3 系统在默认情况下是关闭远程 Finger 服务的。Finger 协议可以帮助用户查询系统中某一个用户的细节,如用户名、地址、电话和登录时间等。Finger 协议用于查找主机及其网络上的用户信息,可以查询站点的在线用户清单及其他一些有用的信息。根据 RFC1288, Finger 是基于传输控制的协议。在本地主机打开一个远程主机在 Finger 端口的连接。使远程主机的 RUIP(远程用户信息程序)变成有效来处理该请求。本地主机发送给 RUIP 一行基于 Finger 查询说明的请求,然后等待 RUIP 的响应。RUIP 接收和处理这个请求后,返回应答,然后发起连接的关闭。本地主机接收到应答和关闭信号后,执行本地端的关闭,协议执行完毕。

2. FINGER 协议的安全问题及防护措施

由于安全性较低,现在很多主机都关闭了这项服务。不过互联网上仍然有相当数量的主机在继续提供 Finger 服务,但 Finger 服务却给网络安全带来了很大的危害。由于 Finger 服务一般都是提供在线用户的用户名,因此入侵者通过 Finger 服务可以轻松地取

得有效用户名列表。如果耐心地多试几次，基本上可以得到大部分的用户名，然后黑客可以使用暴力密码破解器，往往能在较短的时间里得到一个有效的用户“身份”，如 FTP 权限和 Telnet 权限，甚至得到一个有写权限的账号。那么黑客以此作为进一步行动的跳板，所以也可以说，使用 Finger 就等于是开门揖盗。利用 Finger 服务可以取得用户的登录时间，查看邮件时间等有用的信息，这个也是一般入侵者所关注的重要信息，因为可以了解用户的登录时间和习惯，有利于隐藏行踪。Farmer 和 Venema 曾这样评价 Finger 协议：这是一种最危险的服务，它可以被黑客用来调查并发现潜在的攻击目标。它所提供的信息，很可能被黑客用来实施口令猜测攻击。黑客还可以从这些信息中发现用户最近与哪个实体相连，这个实体可能成为潜在的攻击目标；黑客还可以发现用户最后使用的是哪个账号。黑客对那些很少使用的账号非常感兴趣，因为这些账号的所有者很难发现他们的账号遭到滥用。Finger 协议不可能在防火墙上运行，因此对于受防火墙保护的网站来说，它不是主要考虑的问题。对于防火墙内部的用户来说，可以使用其他办法获得大量同样的信息。但是，如果把一台机器暴露在防火墙外部，那么关闭 Finger 后台程序，或者对其施加某些限制才是明智之举。

3.4.20 Whois 协议

1. 概述

Whois 协议运行于各域名注册机构，用来查询域名所有者的身份及数据库中的其他信息，如所有者（Registrant Name）、所有者联系邮箱（Registrant E-mail）、注册商（Sponsoring Registrar）、注册日期（Registration Date）、到期日期（Expiration Date）、域名状态（Domain Status）和 DNS 服务器（Name Server）等。Whois 在一种专门的 Whois 服务器上查询，这种服务器上有个个人或站点信息的大型数据库（如 InterNIC 数据库），只要是在它上面登记过的人员或站点，Whois 就可以查到它们。目前国内提供 WHOIS 查询服务的网站有万网、站长之家等。该协议使用的默认端口号是 43。

2. Whois 协议的安全问题及防护措施

Whois 服务器有很多，并不是每个服务器上都有所查对象的信息，而应在对象所属区域内的 Whois 服务器上查询，查询者才有可能查到正确的结果。Whois 服务器大致按国家和地区（洲）分类，如中国的 whois.cnnic.net.cn，日本的 whois.nic.ad.jp，亚太地区的 whois.apnic.net，欧洲的 whois.ripe.net 等。找到 Whois 服务器后，在 query 框中输入一个人名，在地址框中输入其所在国或洲的 Whois 服务器地址，就可能查到其联系信息。如果要查询一个站点的联络信息，可以直接在地址框中输入站点地址。

查询到的信息除了站点的必要信息之外，还有站点所有者的隐私信息，比如家庭住址、电话号码和电子邮件地址等信息。这些信息可能会通过开放式的 Whois 查询而泄露，继而被有目的的攻击者利用。此外，在进行 Whois 查询时，大多数情况下，人们使用的是客户端软件。黑客曾使用这一服务攻破注册数据库，并对数据库进行了非授权的修改。发生这种情况，是 Whois 服务器没有对输入进行检查所致，导致了包含大量站点信息的数据库的内容的泄露。

针对以上几种问题,目前存在的解决办法相对较少。如果要查询只能联系对应的注册商,那么可以使注册商对国际域名的 Whois 信息屏蔽。这种保护机制是防止有人恶意利用这种 Whois 信息的联系方式,暴露客户的隐私信息。如果域名持有者要注册 Whois 服务,可以取消填写家庭住址和电话号码等信息的填写要求,这是从信息源头上解决隐私信息的泄露。对于黑客针对数据库的攻击,迄今为止,人们并未对 Whois 服务进行过仔细的检查 and 测试,如果网站提供这种服务,应该对该服务的代码进行仔细检查,因此该服务存在一定的风险。

3.4.21 LDAP 协议

1. 概述

LDAP (Lightweight Directory Access Protocol) 的全称是轻量级目录访问协议,类似于 X.500,以目录的形式来管理资源。LDAP 简化了烦琐的 X.500 协议,在功能性、数据表示、编码和传输方面做了改进。1997 年,第 3 版 LDAP 协议成为因特网标准,协议的默认端口号是 389。在介绍 LDAP 之前,有必要先引入目录的概念以进一步理解 LDAP。

目录 (Directory) 是一种专门的数据库,服务于各种应用程序,具有通用性和标准性。大多数人熟悉各种各样的目录,如电话簿、黄页和电视指南等,称为日常目录。计算机中的目录称为在线目录。目录服务是软件、硬件、策略及管理的集合体,包括多个方面,例如目录中的信息、信息存取的软件客户端、客户端到服务端以及各服务端之间的网络基础设施等。一些应用类型不能被归为目录,如文件系统、Web 服务和 FTP 服务等。最常用的目录有两类: X.500 和 LDAP 协议。

2. LDAP 协议的安全问题及防护措施

计算机网络中安全是最重要的因素,对于 LDAP 的客户机/服务器模型安全也是必要的考虑条件。当客户和服务端通信时,在不安全的网络上传输敏感信息必须得到保护。归纳起来,LDAP 考虑的安全包括以下几个方面:

(1) 用户认证。保证客户的身份与客户所声明的一样。

(2) 数据完整。保证服务器收到的数据没有被篡改。

(3) 数据保密。在可能使数据暴露的地方对数据加密。

(4) 用户授权。保证用户的请求在用户的权限范围内。用户授权必须使用用户认证通过以后才实施。在 LDAPv3 中,用户授权不在协议范围内,而是各个厂商自己完成。

对于用户认证功能,最常用的由 LDAP 提供的方法包括 3 种方式。无认证是指客户在绑定服务器时不提供区分名 DN(Distinguished Name)和密码,服务器自动建立一次匿名会话并分配预先定义好的权限给当前用户。基本认证是指当客户选择基本认证方式时,将提供客户的 DN 和密码以 Base64 编码的方式在网络上传输。服务器检查 DN 和密码是否与目录中的一个目录项吻合来判断用户的合法性。简单认证和安全层 (SASL) 是一个框架,它为面向连接的协议提供额外的认证机制,现在已经广泛用于 IMAP4, SMTP, POP3 和 LDAP 协议的中间层。

需要注意的是,LDAP 与 Finger 服务非常相似,由于两者提供相同种类的信息,因

此面临着相同类型的风险。另外，它使用了 ASN.1 编码，因此也继承了其编码带来的缺陷。

3.4.22 NNTP 协议

1. 概述

NNTP（Network News Transfer Protocol）即网络新闻传输协议[Kantor 等 1986]，是一个主要用于阅读和张贴新闻文章到 Usenet 上的 Internet 应用协议。NNTP 用于向 NNTP 服务器或 NNTP 客户提供新闻的分发、查询、检索和投递。NNTP 采用的会话与 SMTP 相类似，本质区别在于 SMTP 通常是双向的、私密的，也就是在两个用户之间传递消息，而 NNTP 是多向的、开放的，多个用户共同查看同一条消息，任何人都可以对消息进行评价和讨论。

NNTP 使用 TCP 端口号 119，也像其他 Internet 应用（HTTP，FTP 和 SMTP 等）一样使用命令和响应实现通信，客户发送 ASCII 命令给服务器，服务器返回数值的响应码，后面跟着可选的 ASCII 数据。验证 NNTP 协议最简单的方法就是利用 Telnet 程序来连接一台主机上的 NNTP 端口，前提条件是这台主机运行了 NNTP 服务器程序。但是，通常我们必须从一台能被服务器主机识别的主机上运行客户程序，典型的情况就是选择同一组织网络中的一台主机。例如，通过 Internet 从其他网络的主机上登录本地的新闻服务器，会收到如下错误信息：

```
vangogh.cs.berkeley.edu % telnet noao. edu nntp
```

```
Trying 140.252.1. 54 ...
```

由 telnet 客户程序输出

```
Connected to noao. edu.
```

由 telnet 客户程序输出

```
Escape character is '^]'.
```

由 telnet 客户程序输出

```
502 You have to permission to talk.Goodbye.
```

由 NNTP 服务器输出

```
Connection closed by foreign host .
```

由 telnet 客户程序输出

输出的第 4 行是由 NNTP 服务器输出的，响应码是 502。当 TCP 连接被建立后，NNTP 服务器收到客户的 IP 地址，将它与配置中的 IP 地址进行比较。如果从一台“本地”主机连接到新闻服务器，则不会收到类似错误信息。

2. NNTP 协议的安全问题及防护措施

由于 NNTP 不必让用户直接连入服务器，这相比 SMTP 相对安全一些，但关于 NNTP 如何通过防火墙还有一些争论。最直接的方式是把它视同邮件，即接收和发送的消息条目通过网关来处理和转发，但这种方法也存在一些缺点：

（1）网络消息非常耗费系统资源。它消耗了巨大数量的磁盘空间、文件位置、节点和 CPU 时间等。网关管理员或许会利用处理数据的相关程序来处理每天多达数 GB 的网络消息。但任何程序都可能会带来安全漏洞，在 NNTPD 中已经存在过这样的问题，在网络消息子系统的其余部分也同样存在类似问题。消息的分发软件包含 SNMTP，这是一个相对简单而且可能更安全的 NNTP。它缺乏一些 NNTP 的功能，但是对于通过网关传递消息来说是合适的，至少不需要每个服务都以 root 的权限运行。

(3) 很多的防火墙结构在设计时假设网关可能遭受攻击, 也就是说, 在网关上不能够部署公司内部所有的新闻组, 同时网关也不能够作为内部消息的“集线器”。

(4) NNTP 与 SMTP 相比有一个最大的好处: 通过 NNTP 可以了解邻居是谁, 可以利用这个信息来拒绝不友好的连接请求。如果网关确实要接收消息, 就需要利用一些机制。可能采用 NNTP 来传递接收到的消息。这样, 如果 NNTP 存在漏洞, 内部的消息主机将会很危险, 因为只要控制了网关, 就可以对它进行攻击。

正是由于以上原因, 有人建议在内部机器运行 NNTP 时, 使用一种隧道策略, 在防火墙上开凿一个加密隧道, 以便让这种数据流通过。

注意: 这种选择不是完全没有风险的。如果 NNTPD 本身仍然存在问题, 攻击者仍能够穿过隧道。但是任何其他方式都不会有分离的传输机制, 同样会使系统暴露在类似的险境中, 比如 uucp, 尽管它本身具有非常安全的通道。

习 题

一、填空题

1. 主机的 IPv4 的地址长度为_____b, 主机的 MAC 地址长度为_____b。IPv6 的地址长度为_____b。
2. ARP 的主要功能是将_____地址转换成为_____地址。
3. NAT 的主要功能是实现_____地址和_____地址之间的转换, 它解决了 IPv4 地址短缺的问题。
4. DNS 服务使用_____号端口, 它用来实现_____或_____的映射。
5. SMTP 服务使用_____号端口发送邮件; POP3 服务使用_____号端口接收邮件; IMAP 使用_____号端口接收邮件。
6. FTP 的主要功能是实现文件的上传和下载, 它的数据通道采用 TCP 的_____号端口, 而其控制通道采用 TCP 的_____号端口。
7. Telnet 服务的功能是实现远程登录, 它采用 TCP 的_____号端口。
8. SSH 服务的功能是实现安全的远程登录, 它采用 TCP 的_____号端口。
9. SNMP 服务的功能是实现网元的管理, 它采用 UDP 的_____号端口。
10. NTP 服务使网络内的所有设备时钟保持一致, 它使用 UDP 的_____号端口。

二、简答题

1. 简述以太网上一次 TCP 会话所经历的步骤和涉及的协议。
2. 在 TCP 连接建立的 3 步握手阶段, 攻击者为什么可以成功实施 SYN Flood 攻击? 在实际中, 如何防范此类攻击?
3. 如何封装一个源路由数据包? 允许这种数据包通过防火墙会对内部网络安全造成什么影响?
4. 为什么 UDP 比 TCP 更加容易遭到攻击?
5. 为什么路由协议不能抵御路由欺骗攻击? 如何设置路由器抵御这一攻击?

6. 写出 DNS 服务的 CheckList（安全检查步骤）。
7. 通过 DNS 劫持会对目标系统产生什么样的影响？应该如何避免？
8. 简述 IPv6 和 IPv4 的数据包格式的异同。在 IPv4 网络上打通 IPv6 隧道的方式有哪些？
9. IPv6 和 IPv4 网络能否互通？如果可以，需要哪些辅助措施？
10. 能否在 ARP 层进行会话的劫持？如果能，原理是什么？
11. 黑客为什么可以成功实施 ARP 欺骗攻击？在实际中如何防止 ARP 欺骗攻击？
12. 判断下列情况是否可能存在？为什么？
 - (1) 通过 ICMP 数据包封装数据，与远程主机进行类似 UDP 的通信。
 - (2) 通过特意构造的 TCP 数据包，中断两台机器之间指定的一个 TCP 会话。
13. 什么是 ICMP 重定向攻击？如何防止此类攻击？
14. 在内部以太网局域网中，能否根据一个 ARP 地址（MAC 地址）唯一确定一台主机？能否根据给定的一个 ARP 地址唯一确定拥有者的身份？
15. DNS 可能遭到的攻击有哪些？DNSsec 协议有哪些优点？
16. 在邮件应用中，IMAP 与 POP 相比较，最大改进是什么？
17. FTP 和 H.323 都被称为动态协议，为什么？
18. 使用 SSH 进行通信是否能够避免会话劫持？为什么？
19. SNMP v1 和 SNMP v3 有哪些不同？SNMP v3 中主要做了哪些改进？
20. 简述在多播通信中，通信各方发送数据包的类型，以及源、目的地址的特征。
21. 电子邮件系统通常面临哪些安全风险？在实际中，人们采用哪些安全措施来提高邮件系统的安全性？
22. FTP 服务存在哪些安全风险？应如何做才能消除或减少这些安全风险？
23. 请比较 Telnet 和 SSH 协议的异同，并用 Sniffer 软件捕捉其数据包查看两者的数据包内容有何不同。
24. 简述 H.323 协议与 SIP 的异同。